What It Takes to Trust a Measurement: Instrument Failures in an LLM Malware-Analysis Pipeline

Abstract

Multi-agent LLM pipelines map malware evidence to MITRE ATT&CK techniques, and their components are rarely measured against the deterministic tooling they sit on. We evaluate one, and report why several of our own measurements of it were wrong.

Scored per sample on the same binaries and ground truth, the full pipeline reaches F1 0.1160 against 0.1130 for the sandbox it is built on, paired +0.0030 [−0.0353, +0.0344], at a resolution of 0.085. On 24 real samples, one per family, negotiated multi-agent consensus beats a single judge by +0.0537 F1 [+0.0362, +0.0714], and so does a noise control, by +0.0532. The two differ by +0.0005 at a resolution of 0.046. What helps is the calls the arms share, not the negotiation. Verbal confidence, which every deterministic gate consumes, ranks correct claims above incorrect ones at AUC 0.550, on an interval containing chance.

Seven defects in our own instrument produced plausible results rather than errors, and 2,753 passing tests caught none. Four crossed a boundary with another server; the other three share a shape, a measurement's cause assigned rather than measured. The largest is this paper's own statistics. Every interval we published resampled rows when the observations were clustered, and correcting it widened our anchor interval 2.32-fold and turned two equivalence claims into bounds.

We contribute the measured negatives with the minimum detectable effect beside each, seven failure mechanisms with what found them, and a no-LLM baseline (F1 0.1526, n=97) without which none of these numbers means anything.

Keywords: LLM agents, malware analysis, MITRE ATT&CK, evaluation methodology, clustered inference, negative results

1. Introduction

Three claims organise this paper.

First: the architecture we built did not survive its own evaluation. The system is a multi-agent pipeline over static, dynamic and network evidence, with a corroboration cascade, two retrieval tiers, and deterministic confidence gating. Each component was motivated by a plausible mechanism. Measured at equal token budget against simpler alternatives, the multi-agent design does not beat a single judge; the corroboration set never changes a verdict; the confidence number the gates consume discriminates at AUC 0.550; and all three retrieval components are near-inert end to end despite working in isolation. We report these as results rather than as tuning opportunities.

Second. Those nulls are only interpretable because we measured whether each mechanism fired. A deterministic confidence cap that fires on 0.82% of techniques produces an ablation whose null result says nothing about the cap. A priority hint that fires on 56.7% of samples produces one that does. We adopted firing rate before effect as a rule after the first case, and it changed which experiments were worth running.

Third, and the reason for the paper's title. The instrument was repeatedly wrong in ways that looked like data. Over one week we found four defects at the boundaries between the pipeline and the servers it depends on. In each case a server answered successfully and answered about something else: an argument the agent never supplied arrived as an explicit `null`; a program reported as loaded, by name, never became the one being analysed; a refused load returned HTTP 200 with an error in the body; and two bounds designed to protect the analyst composed into a path that returned nothing at all. None was caught by 2,753 passing tests, because each needs a *second* case in one server lifetime, and a unit test writes one.

Every one of those four was caught the same way. A number repeated where variation was expected. A hint of exactly 2,575 characters for two unrelated binaries; call graphs identical to the character for samples of 241 KB and 139 KB; 66 consecutive samples at 75,426 characters. The check costs one line, needs no ground truth, and we now report it beside every batch result.

Then three more, and none of them was at a boundary. An ablation varied a deterministic reconciliation step and we attributed its output to a language model. A rank correlation over model size ranked a reasoning-configuration flag instead and recovered the published scaling coefficient almost exactly, agreeing with the literature, which is the direction a result is least likely to be questioned. And a documented output ceiling on the judge was renamed by our client library during serialisation to a key the inference server does not read, so a component we describe as bounded had never once been bounded. The detector above does not find these, because their outputs *do* vary; two were caught by a number too clean to believe and one by a study that recorded which failure branch each call took. Each had passing unit tests over the exact function concerned, because the defect was never in a function but in which measurement was attributed to which cause, or in which representation of a value crossed a boundary.

We report them because the correction is part of the result. Two published findings of ours were withdrawn or rewritten on their account, a third was one report away from being published as a scaling law, and a completed 210-sample study is withdrawn from this paper because it met the precondition for one of the defects and its per-sample outputs were not retained, so whether it was affected cannot be established.

We do not claim the category, and we counter-searched the newest mechanisms before claiming them. Silent failure, an error that produces wrong behaviour without an actionable signal, is a long-established and taxonomised class in production software [1, 2, 3], LLM-specific runtimes are now being taxonomised along the same lines [4, 5], "distinct inputs should produce distinct outputs" is an ordinary metamorphic relation [6], an inference-time constraint inverting model rankings inside a constrained budget is established [7, 8], and silently overruling a request parameter to a default is a named failure mode with a measured prevalence [9]. Three of our four boundary mechanisms therefore sit inside a peer-reviewed class. The fourth does not, and we say which: we found no reviewed source establishing that OpenAI-compatible servers disagree about *which* token-limit parameter they honour, so we claim no priority for it either.

What we add is the setting and the price. An evaluation pipeline for security research, where the artefact is not a degraded user session but a measurement that is wrong and looks right.

Contributions. Each maps to one section, and each is a measurement or a mechanism rather than a proposal.

We report a no-LLM baseline for LLM-based ATT&CK mapping, and the full pipeline scored against it on the same samples and the same ground truth, the comparison without which every F1 in this literature, including our own earlier ones, refers to nothing (Section 5.1). We report four measured architectural negatives, multi-agent consensus at equal budget, a corroboration cascade, two-tier attribution and a confidence gate, each with the minimum detectable effect of the design that produced it, because a null without its resolution is unreadable (Section 5.2 to Section 5.7). We report seven instrument failures that produced plausible results rather than errors, with the layer each occurred at and what actually found it; four crossed a boundary with another server, and three were inside our own code and share a different shape (Section 6).

Two things follow from those failures. One is a one-line detector, how many distinct outputs did N inputs produce, which found all four boundary failures, needs no ground truth, and is reported beside every batch result rather than written as a test (Section 6.3). The other is a selection rule that follows from a provider accepting a parameter and not acting on it, namely that arms must be matched on their *measured* configuration rather than their requested one (Section 6.1.7). The price is demonstrated rather than hypothesised. One completed 210-sample study is withdrawn because its question can no longer be asked of it, and four arms of a later ablation are unattributable for the same reason one level up (Section 6.4).

2. Background and Related Work

2.1. Mapping evidence to ATT&CK

Language models are already applied across the malware task surface, tracking malicious packages in a registry [10], detecting Android malware from application features [11] and from generated training samples [12], and summarising what a sample does in prose [13]. None produces ATT&CK technique identifiers from a running analysis of a Windows binary, which is the task this pipeline attempts and the reason the work below is the nearer comparison.

Automated technique extraction has moved from supervised classifiers such as TRAM [14], rcATT [15] and TTPDrill [16], through neural extractors such as EXTRACTOR [17], AttacKG [18] and LADDER [19], to retrieval-augmented generation. TechniqueRAG [20] pairs off-the-shelf retrievers with an instruction-tuned reranker and fine-tunes only the generator, motivated by the field's data scarcity, since ATT&CK defines over 550 sub-techniques while roughly 10,000 annotated examples exist publicly. A *separate* group's hierarchical successor, H-TechniqueRAG [21] [preprint], injects the tactic-to-technique taxonomy as an inductive bias and cuts the candidate space by 77.5%. Its F1 and latency gains over TechniqueRAG are not restated here, being unreviewed and self-reported against a baseline the SoK below calls "largely incomparable". TTPrint [22] [preprint] decomposes reports into atomic behaviours and keeps only candidates supported by both a localised evidence span and the MITRE definition. Büchel et al.'s SoK [23] re-evaluates 40+ systems in a unified setting and reports a ceiling existing approaches have not crossed, that systems are "largely incomparable" because they use custom ontologies and inaccessible datasets, and, counterintuitively, that traditional NLP approaches outperform embedder-based and generative ones in realistic settings.

Our describe-then-map design removes technique-ID recall from the model entirely, so the analyst describes behaviour and a deterministic index assigns the identifier. This is a domain instantiation of Infer-Retrieve-Rank [24] [preprint], which established the general program of multi-step interaction decoupling inference from assignment over a many-thousand-class label space, and we do not claim the idea. Ours is stricter than that and than [20], where the model still ranks or selects among retrieved candidates. Here it never emits an identifier and any correction is gated to the provably-safe invalid-to-valid case.

What we add is a decomposition of the SoK's insight. It reports that embedders lose and we measure *where*, on TRAM2 [14] at N=4,913 and on the independently annotated AnnoCTR corpus [25]. Ranking quality and gate quality behave as separable axes. Dense embeddings rank better while their scores barely separate a correct pick from a wrong one, a lexical index ranks worse while gating cleanly, and composing the per-axis winners beats either pure backend on both. The separation itself is not ours and an earlier draft of this section claimed it was. Abdallah et al. [26] treat retrieval confidence as a dimension explicitly distinct from effectiveness, find calibration "consistently weak across model families" and conclude that raw scores are "unreliable for downstream routing without additional calibration". What remains ours is the inversion, that in this task the *lexical* backend is the better gate while the *semantic* one is the better ranker, and we found that neither asserted nor excluded elsewhere.

Two further results have prior art we cite rather than compete with. Auto-correcting valid but weakly-aligned identifiers damages 38% of already-correct labels to recover 21% of wrong ones, and the asymmetry is not a discovery, since grammatical error correction evaluates with F0.5 precisely because a false correction costs more than a missed one [27, 28]. Our contribution is the *mechanism*, that correct-but-weak and wrong-but-valid identifiers are not separable by an alignment score, so the valid-to-valid swap cannot be safely tuned at any error rate and the shipped policy is restricted to the invalid-to-valid case, where zero regression holds by construction rather than by tuning. Separately, asked for an identifier it does not know, the model enters a degenerate loop, and neural text degeneration has competing established accounts, one locating the cause in the likelihood objective itself and a later data-side analysis finding a strong correlation with repetition already present in the training data [29, 30]. The engine-level detail we can add is that the server honours `repeat_penalty` while silently ignoring three sibling parameters, which converts a tight loop into a slower enumeration without fixing it. What we contribute is the consequence, measured in Section 5.8, where the budget is exhausted inside an operational deadline and empty bundles fall from 6/17 to 1/17. That is degeneration as a failure to *deliver* rather than a failure of prose.

2.2. LLM agents over binaries

Agentic systems now drive reverse-engineering backends through tool interfaces, and the model tier splits sharply by role. Fine-tuned binary specialists are overwhelmingly small and open-weight, among them ReCopilot [31] [preprint] on Qwen2.5-Coder-7B, LLM4Decompile [32] at 1.3B to 33B and Nova [33], while the *tool-driving* agents use frontier models. TTPDetect [34] [preprint] is the closest system to ours, identifying TTPs in stripped malware binaries through dense plus neural retrieval to narrow analysis entry points and then a function-level agent with incremental context retrieval, reporting 93.25% precision and 93.81% recall at function level and 87.37% precision on real-world malware. We do not claim binary evidence as an input modality; that ground is theirs. Two differences remain and only one is currently defensible. Our pipeline runs on a local MoE with roughly 3B active parameters rather than a cloud model, which is a deployment claim addressed in Section 3.2, and it fuses six deterministic detectors, three domain analysts and a corroboration cascade rather than reasoning at function level, which is a different system but not a contribution until the difference is measured.

The one gap we do occupy is tool-catalogue scale. Degradation of tool selection as the catalogue grows is documented generally, with LongFuncEval [35] [preprint] reporting a 7 to 85% performance drop as tool count increases and a cut from 46 to 19 tools saving up to 70% of execution time on an edge model [36], but it has not been measured for a reverse-engineering catalogue where schemas are large and tools semantically overlap. Our finding that exposing roughly 201 Ghidra MCP tools, about 22k tokens of schema, is infeasible at this model scale, which motivates a curated 20-tool allowlist with high-value tools invoked deterministically from code, is the domain instance. It is a single feasibility point rather than a degradation curve.

2.3. Multi-agent consensus

Multi-agent debate has become a standard pattern, including in security, where PhishDebate [37] assigns four specialised agents to distinct views of a webpage under a moderator and judge and reports 98.2% recall. Two 2026 results change how such claims must be read. Holding the reasoning token budget constant, Tran and Kiela [38] [preprint] find single agents consistently match or beat multi-agent systems on multi-hop reasoning, supported by an information-theoretic argument from the Data Processing Inequality, because decomposition under a fixed budget introduces communication bottlenecks that lose information. Bertalanič and Fortuna [39] reach the same conclusion on 7B and 8B open-weight models, where debate consumed 2.1 to 3.4× more tokens for equal or lower accuracy, and name three failure modes, namely sycophantic conformity with modal adoption up to 85.5%, contextual fragility, and consensus collapse discarding correct answers already present in the generation pool.

We do not claim that multi-agent analysis beats a single agent, and we report the equal-budget comparison rather than assuming it. Both papers scope their negatives to *homogeneous* agents decomposing a *single* context and both name the exception, degraded or noisy context, which is the regime a 600-import binary plus a sandbox report plus network capture occupies. Whether heterogeneous evidence-channel decomposition survives the control that homogeneous debate fails is the question our ablation asks.

Our contribution here is a failure mode adjacent to [39]'s. Sycophantic conformity arises from majority pressure among agents holding the same information; we observed an analyst whose evidence channel was empty paraphrasing its peers, and because the echo returned tagged with that analyst's own domain, the corroboration counter read it as independent confirmation, promoting a single-source finding to *corroborated* and weighting it above the source it was copied from. In a security pipeline the harm is not a wrong answer but a fabricated independent confirmation. Finally, weighting evidence by source reliability and discounting non-independent sources is Dempster-Shafer theory, decades old, and our cascade is an instance of it with hand-chosen constants, which we treat as a limitation. Measuring five perturbations of those constants, including inverting the most- and least-trusted layers, changed the top-10 ranking on 10.6 to 27.5% of samples and the corroborated set on none, because the corroboration decision is a function of layer count alone.

2.4. Local deployment

Confidentiality-driven local deployment is established rather than novel. REx86 [40] fine-tunes eight open-weight models for x86 reverse engineering explicitly because "cloud-hosted, closed-weight models pose privacy and security risks and cannot be used in closed-network facilities", and validates with a 43-participant user study in which line-level comprehension improved significantly at $p=0.031$ while the correct-solve rate rose from 31% to 53% without reaching significance at $p=0.189$. The capability gap is quantified: the UK AI Security Institute places open-weight cyber capability 4 to 7 months behind the closed frontier, narrowing from 6 to 10 months, at roughly 45× lower cost per task.

We inherit this constraint and cite it rather than claiming it. Our deployment contribution is narrower and practitioner-facing. On a hybrid-offload MoE the KV cache costs about 10.85 KiB/token and context length barely moves system RAM because the cost is the offloaded weights, a closed-form estimate over-predicted KV by roughly 4× and was overturned by measurement, and speculative decoding gave no throughput gain on this architecture. We found no comparable deployment-economics reporting for a complete local security pipeline.

2.5. Evaluation practice

This work's methodological results belong to an established critique tradition rather than preceding it. Arp et al.'s *Dos and Don'ts* identified ten pitfalls in ML-for-security, and Chasing Shadows [41] is its direct successor, surveying all 72 peer-reviewed LLM-security papers from 2023 and 2024 and finding that every one contains at least one of nine pitfalls, with only 15.7% explicitly discussed. Broader benchmark audits reach the same place from the construct-validity direction across 445 LLM benchmarks. Our instrument-validity finding, that a single-run parsed-claim count produced contradictory rankings of the same arms across decoding budgets, is a worked example inside that category rather than a new observation. So is our narrative result. That template-based generation favours faithfulness while neural generation favours fluency is textbook data-to-text, and what differs is the mechanism, because in our paired comparison both arms were perfectly faithful, with zero hallucinated techniques and precision 1.0, so the entire F1 deficit came from coverage. The model did not invent; it omitted.

Two evaluation results appear to be unoccupied. First, a case-prior retriever that is genuinely good in its own vocabulary at F1 0.620 against a 0.424 label-frequency prior but scores 0.111 against that prior's 0.123 when queried the way production queries it, because query and corpus share only their boilerplate. Dense retrieval being the standard remedy for vocabulary mismatch makes this a failure of the remedy, visible only in the retriever's score distribution while top-k accuracy stayed healthy. A published negative RAG result in malware analysis exists by a different mechanism, retrieved context diluting a signal-extraction task [42]; the requirement to compare against a trivial label-only baseline is long established [43]; and a systematic review by the same group found a considerable share of published multi-label results to be no better than that baseline, with no explanation offered [44] [preprint]. Second, an advisory prompt hint whose measurable effect was completion under an operational time budget rather than mapping accuracy. We found no work measuring generation completion as a channel through which prompt changes act.

Finally, temporal stability, where the axis matters more than the result. Performance falls as evaluation moves away from the training period and scale does not close the gap [45], but that work varies the distance between training time and test time while ours fixes the model and varies the era of the input binary, which is concept drift in the malware-detection sense applied to an LLM analyst. We find no LLM-based equivalent on that axis, and we no longer have a result to report on it. Our n=210 drift study is withdrawn because it drove the full pipeline per sample against a long-lived shared Ghidra server that was never restarted, which is the precondition for the stale-program defect described in Section 6, and its per-sample outputs were not retained, so whether it was affected cannot be determined after the fact. What survives is the framing, and a re-run under the corrected instrument is required before any bound is claimed.

2.6. *Silent failure at tool boundaries*

The paper's methodological spine belongs to an area that already exists, and locating it there precisely matters more than claiming the ground. The genus is described and the description is older than this field. Gunawi et al. [1] measured where an error signal is lost, finding that 13% of propagation channels drop an error code without handling it and that calls between modules are a major cause. Yuan et al. [2] ruled that a handler which only logs is a handler that ignores, and attributed 25% of catastrophic failures to errors that were explicitly signalled and then ignored. Alquraan et al. [3] found the majority of network-partition failures in cloud systems to be silent, with every warning the rest produced "confusing, with no clear mechanism for resolution", which is the meta-pattern our defects share, stated in an operating-systems venue a decade before the runtime we built.

Our three boundary defects sit inside that description without strain. An unset optional argument sent as `null` and a `load_program` that does not change what the server is looking at are design-assumption mismatches, and a refused load answering HTTP 200 is error swallowing in the sense Yuan et al. define. The LLM-specific instance of the same shape is now being catalogued too, in bug taxonomies for agent orchestration frameworks [4] and for the inference engines we run on [5], the latter carrying both *incorrect request parsing* as a root cause and *silent error* as a symptom. Adjacent work reaches the same place from the interface side. Mining defects in MCP reference servers, Oyelayo et al. [46] find data validation and type issues to be the second most prevalent class at 13.97%, the bucket our null-for-unset-optional bug falls into, and input dependencies that a machine-readable specification cannot express are "the norm, rather than the exception, with 85% of the reviewed APIs" carrying them [47]. The detector is not new either. "Distinct inputs should produce distinct outputs" is an ordinary metamorphic relation, and metamorphic testing exists precisely for programs whose correct output is unknown [6], the "notorious oracle problem" its own survey names. Stress-testing an LLM judge's consistency under input variation is likewise established, and [48] perturbs formatting, paraphrase, verbosity and ground-truth labels to measure how the judgment moves.

The newest of our mechanisms is a domain instance rather than a discovery. Building a parameter-size series, we produced a rank correlation of +0.866 between model size and F1, reproducing the ρ=0.85 the nearest prior work reports [49] [preprint], from an axis on which the low-scoring row was a model disabled by a configuration flag rather than limited by its size. That phenomenon is established, though more narrowly than we first wrote it: under strict output-length constraints performance "might not scale monotonically with the model size" [7], an inversion local to the budget regime rather than a global reversal, and the same source reaches our confound independently, since reasoning models do not always beat instruction-tuned ones under that constraint and a reasoning flag consumes the answer budget. The general form is better established still. Across 6.5M instances inference-time configuration moves performance “both absolute and relative” [8], the relative half being the ranking a single-configuration comparison silently fixes, and extra test-time compute lets a smaller model overtake a much larger one [50, 51], while lengthening reasoning steps improves accuracy [52]. Read together the effect is task- and budget-dependent rather than monotone in either direction, which is our argument rather than an objection to it.

What we would add sits in the remedy rather than the phenomenon. Their protocol is adapted per model; ours has to be verified per arm, because one of our providers accepts the parameter that would match two arms and does not act on it, so selection has to key on the *measured* reasoning share of a completed arm rather than on the flag requested. The same is true one layer down, where OpenAI-compatible servers disagree about which token-limit parameter they honour, documented in their own issue trackers [53, 54] [preprint]. So what we add is narrow: three instances of the described genus drawn from an evaluation pipeline for security research, where the consequence is a measurement that is wrong and looks right rather than a bad answer to a user; the output-cardinality check reported *alongside* the result rather than run as a test; and a demonstrated cost, one study withdrawn because the question can no longer be asked of it. The taxonomies report incidents, and we report what an incident of this class does to a result already written down. One further observation is offered as a proposal and developed in Section 7.2: those taxonomies are organised by the boundary crossed, three of our seven mechanisms crossed none, and the principle covering both is not the boundary but the attribution.

2.7. *Scope of every empirical statement above*

Each of our results cited in this section was produced on one model on one machine, Qwen3.6-35B-A3B at IQ3_K_R4 quantisation served by ik_llama.cpp `llama-server` on a single RTX 5060 host with 31 GiB of RAM, with the exact model revision, GGUF digest and engine commit recorded in the reproducibility appendix. Where a statement concerns retrieval or the deterministic cascade rather than generation, no model was involved at all and the binding limit is the index and the corpus instead; those are marked at the point of claim.

We state this here rather than only in Threats to Validity because [41]’s surrogate fallacy is the pitfall this work is most exposed to, and because the nearest external evidence sharpens it. In an ATT&CK-classification study across models, parameter size was the only statistically significant predictor of F1, at ρ=0.85 and p=0.014 [49] [preprint], while prompt strategy, chain-of-thought and temperature were not. Single-model findings are therefore exactly the kind that should not be read as properties of an architecture. Where a result is a *negative* obtained under a configuration favourable to the alternative, it travels further than a positive, and we say which is which at each claim.

2.8. *Reference note*

Verification status is recorded per entry in the bibliography rather than asserted in aggregate. An entry read only as an abstract says so, and the three that had been cited for something the source does not say carry the correction. Twelve systems were named in this section with no record of their own, cited through the verified sources that discuss them, which is a polite way of saying the paper asserted twelve attributions it had not checked, in a section whose subject is unchecked attribution. Each now carries its own entry. Eight sources remain unreviewed and are marked [preprint] at every use; each exists to concede ground rather than claim it, and removing them for want of a venue would have made this paper appear more original than it is.

Two quoted figures had been attributed to papers that do not report them, and the pair has a shape worth naming because it is the one this paper's own machinery was blind to. Neither number was invented and both are real figures from real papers. What went wrong was the binding, a value recorded against a key that never reported it, and a checker asking only whether a number is registered cannot see that. The registry is now checked in the opposite direction as well. A quoted value must appear in the text beside the citation it is declared to come from, so a binding that has drifted fails the build rather than reading as verified.

3. The System, Briefly

3.1. Shape

The pipeline maps evidence about a malware sample to MITRE ATT&CK technique IDs and emits a STIX bundle. Three analysts run over heterogeneous evidence channels, a judge synthesises a verdict, and a deterministic layer adjudicates between them.

Whether each contributes anything measurable is the subject of Section 5.

Two design choices matter here because they are *not* what failed. Tool exposure is not tool availability: the reverse-engineering server advertises ~165 tools, exposing the full catalogue to a 3B-active-parameter MoE is infeasible because the model's tool selection degrades before the context does, and the analyst is therefore given a curated 20. And the pipeline degrades rather than fails when a service is absent, so with the sandbox unreachable the dynamic path is skipped and the run completes on static evidence, which is pinned by a test. That mattered during the study, because the sandbox was reachable from one network only and every static-only result here was produced by that degradation working as designed.

3.2. What runs it

The system runs one local model, Qwen3.6-35B-A3B at IQ3_K_R4, served by ik_llama.cpp on a single RTX 5060 host with hybrid MoE offload . Alongside it run a headless reverse-engineering container, a Qdrant vector store, and a CAPEv2 sandbox on a separate machine. Exact identifiers are in the reproducibility appendix, and their limits are not incidental: the model server's memory grows with cumulative requests, generation rate varies eightfold with context length on this architecture, and the sandbox retains its reports for days. Each of those shaped an experiment reported here.

Table 1: The pipeline's components and what each contributes, as built.

component	what it does	verdict
static analyst	ReAct loop over a headless reverse-engineering server (decompilation, imports, strings, call graph), 20 tools from a curated allowlist	operational; its salvage path was defective (Section 6)
dynamic analyst	ReAct loop over a CAPEv2 sandbox via MCP	operational; only Windows PE is analysable on our instance
network analyst	local PCAP analysis over the sandbox's capture	operational; depends on the sandbox indirectly
judge	synthesises a verdict and emits STIX	operational
corroboration cascade	weights layers, marks a technique corroborated when ≥2 layers contribute	measured: never reaches the artefact (0/32); a reconciliation step restores every cascade technique the judge omits, and across 80 arms the judge added none of its own
confidence gating	caps confidence for unsupported obfuscation/injection claims	measured: fires on 0.82% of techniques
case-prior RAG	retrieves similar past cases to prime mapping	measured: loses to a label-frequency prior in production
family-feature RAG	retrieves family fingerprints	measured: +0.0029 F1 end to end
opcode-hash attribution	normalised function hashes matched against a corpus	measured: fires on 0 of 18 samples
sink-reachability hint	ranks functions reachable to sensitive APIs, injected as prompt steering	fires on 56.7%; measured: ΔtechniqueIDs +0.50, CI [−3.33, +4.50]

3.3. Why the system is not the contribution

The architecture was built around four claims: multi-agent consensus over heterogeneous channels, a multi-layer corroboration cascade, two-tier attribution, and falsification-before-confidence. All four are now measured and every one is negative or near-null, with none left pending sandbox access. The components are not broken, three work well in isolation, and they were built for sound reasons; they simply do not move the end-to-end result, and we could not have known that without measuring each mechanism's firing rate before its effect.

That outcome is the reason this paper is about measurement. A system whose parts individually justify themselves and collectively change nothing is an ordinary result, and reporting it requires only honesty. What required method was discovering that seven of those measurements had been wrong in the first place.

4. Measurement Methodology

4.1. Terms

Four words are used in one sense throughout and are worth fixing before the measurements, because two of them name things this paper spends a figure keeping apart.

An arm is one condition of one experiment. A configuration under which every input is scored, so that two arms differ in the one thing being tested. A run is an execution of a harness, which may produce several arms and may be interrupted and resumed.

A sample is a real malware binary from the dated cohort, scored against its family's MITRE `uses` set. A fixture is one of the five synthesised inputs used by the equal-budget arms, whose evidence is generated from its own technique list and which therefore has a ceiling a real sample does not. They are different populations with different ground truth, they are never pooled, and where both appear in one figure they appear on separate axes.

The reconciliation step is the deterministic post-processing that compares the judge's bundle against the corroboration cascade's set and restores what the judge omitted. It is named here because the paper's central architectural finding is about what it does, and an earlier draft gave it three different names.

4.2. Equal budgets, with a noise control

Arms are compared at an equal total token budget. A multi-agent arm that makes N calls receives B/N per call against a single arm's one call of B, so a win cannot come from spending more. The design follows Bertalanič & Fortuna, including a stochastic-noise control in which one analyst receives evidence irrelevant to the sample.

The control is not decoration. It establishes that the harness can detect a difference. In our consensus study the noise arm separated (0.3366 against 0.3975 and 0.4136) while the treatment did not, which distinguishes "no effect" from "no sensitivity".

For reasoning models the budget must cover reasoning. Our frontier endpoint reports reasoning tokens separately from content, and 56.5% of its output was reasoning across 25 real prompts (84% on a one-token answer). Capping content alone would have granted it roughly twice the generation for the same nominal budget.

And the arms must be on the same side of the reasoning switch, which is a stronger requirement than it sounds. We measured this flag on two models at 25 calls each: enabling it moved F1 by 0.45 on one and 0.34 on the other, in both cases because the model spent its entire output budget thinking and returned no answer; 24 of 25 calls hit the cap on the second model, and one answered. That is the only effect in this paper that exceeds its own design's minimum detectable effect, so an unmatched pair does not produce a noisy comparison; it produces a comparison of the flag. Two further cautions follow from what it took to hold this constant. The flag cannot be read from the request: one of our providers accepts the parameter and ignores it, returning the same reasoning share with and without it, so matching must be verified against the measured reasoning share of the completed arm. And it cannot be assumed uniform across a series. When we ranked arms by parameter count without checking, the ranking recovered the published scaling correlation (ρ=+0.866) from an axis on which one point was a disabled model rather than a small one.

4.3. Paired designs, bootstrap intervals, and never a single run

Every arm sees the same samples in the same order; differences are computed per sample and then aggregated, with 95% bootstrap confidence intervals over the paired deltas.

Resampled at the cluster, and tested at the cluster. The observations are nested, with many claims from one sample and many samples from one family, so the bootstrap resamples whole clusters and the p-value comes from flipping the sign of whole cluster means rather than of rows. Two properties of that test have to be reported with it. The first is its floor. With k clusters the two-sided version cannot return a p below $2/2^k$, which at k=5 is 0.0625 and puts α=0.05 out of reach whatever the effect. The second is that above 20 clusters the 2^k assignments are sampled rather than enumerated, at 20,000 draws with the observed assignment counted in its own reference set, so the smallest p that route can return is one over the draws rather than zero. Each reported p names which route produced it.

We record this because the two properties pull opposite ways and the design has to answer both. Raising the cluster count is what lifts the floor, it is the whole reason the consensus arms were re-run one sample per family (Section 5.2.1), and it is also what makes enumeration stop being possible. A design improved on one axis broke the estimator on the other, and the first version of that estimator responded by returning no test at all.

The motivating failure is specific. An early study ranked prompt structures using a single-run parsed-claim count, and the ranking inverted when the decoding budget changed. The instrument was measuring the interaction of structure and budget while being read as measuring structure. A claim count from one run is not an instrument, and we now say so where that result is cited.

4.4. Firing rate before effect

Before ablating a mechanism, measure how often it engages. The rule came from two cases that look identical in a results table and are not. The confidence cap fires on 0.82% of techniques, so an ablation of it would say nothing, its null describing the 99.2% where the cap never ran; the sink-reachability hint fires on 56.7% of samples, so an ablation of it is a real statement about the hint. Table 9 reports the measured rates. The cap's own preconditions explain its rate, since it applies to three technique families only when the sole contributing layer is static and 84% of those claims are YARA-only, so no static claim exists for it to discipline. Reporting the rate is more informative than ablating it, and cheaper.

A corollary. An ablation must be restricted to the samples where the mechanism fires and must report the remainder separately, because averaging a feature over inputs it never touched dilutes a real effect toward zero and manufactures a null.

4.5. Output cardinality, reported beside every batch

Count how many distinct outputs the N inputs produced. If far fewer than N differ on a dimension that should vary, the instrument is repeating itself. The four *boundary* defects in Section 6 were found this way and none by a 2,753-test suite. The three that are ours rather than a server's were not: their outputs do vary, and what found them was a number too clean to believe, an arms table read under a correlation, and a study that recorded which failure branch each call took.

It is reported as a result column, not run as a test, because the signal exists only in the batch. Each individual response was well-formed and plausible. We report 63 distinct call-graph sizes across 97 samples.

4.6. Per-sample outputs are retained for every study

Aggregates cannot be re-interrogated. When a defect was found that *might* have affected a completed 210-sample study, the question could not be asked, because only the summary survived, and the study is withdrawn as a direct consequence.

The policy is therefore not "keep the numbers" but keep enough to re-ask a question that has not been thought of yet: per-sample predictions, the resolved ground truth, timings, and the identifier of every external task the run depended on.

4.7. Fresh server state per sample

Shared, long-lived servers accumulate state that crosses sample boundaries. In our sweeps, restarting the reverse-engineering server between samples recovered 12 of 14 samples previously recorded as unmeasurable; the failures belonged to the state each sample inherited from its predecessor, not to the samples themselves. A read timeout leaves the JVM mid-analysis and every subsequent load is refused; without restarts, one slow sample silently invalidates the window that follows it.

The same applies to the model server: it grows with cumulative requests and does not plateau (10.4 GB fresh, 14.8 GB after one pass), so long paired runs restart it between arms. At temperature 0 this is measurement-neutral.

4.8. Two audits that cost minutes and caught real errors

Diff the claim register against the evidence log. Both documents are maintained; that is exactly what allows them to diverge. Applied twice here, it found a claim recorded as novel one hour after our own text called it a replication, an audit row mis-attributing a model caveat to a server-free harness, and three ledger rows still carrying superseded figures.

Counter-search each novelty claim in an adjacent field's vocabulary. A claim of novelty is a *searched absence*, and searching in one's own field's words finds nothing by construction. Five claims were demoted this way, including the one central to this paper, when the silent-failure genus turned out to be already taxonomised. Two rules came out of doing it. The first is that a search summary is a lead and not a source; one asserted prior art that neither candidate paper contained when fetched, and citing it would have put a fabricated reference in the ledger. The second is that the result of a counter-search is recorded whether or not it demotes anything, because "we looked and found nothing" is only credible if the looking is documented.

4.9. What this costs

These practices are cheap individually and expensive together, and the expense is honest to report. The firing-rate rule adds a measurement before every ablation. Per-sample retention adds storage (~660 MB of sandbox reports for one cohort). Fresh state per sample adds ~20 seconds of restart to every sample. Output cardinality adds one line.

Against that: one withdrawn study, seven defects that produced plausible wrong data, and three retrieval components that would have been reported as working had they only been tested in isolation. On this project the practices repaid the time they cost, on this project, which is the only argument for them we can make from a single system.

5. Results

5.1. The baseline, first

Every accuracy number in this work is read against one reference, and we state it before any of our own. CAPE alone, the sandbox the pipeline is built on, mapping its signature hits to ATT&CK technique IDs deterministically, with no language model anywhere:

Table 2: The no-LLM baseline.

	mean	95% cluster CI	ICC	effective n
precision	0.2413	[+0.1850, +0.3010]	0.584	35.0
recall	0.1328	[+0.0896, +0.1810]	0.638	33.0
F1	0.1526	[+0.1114, +0.1998]	0.692	31.2

CAPE's own signature-derived technique identifiers, scored against family-level MITRE ground truth. Intervals resample families, not samples. Ground truth is resolved per family, so two binaries of one family are scored against a byte-identical label vector and are not two observations.

n = 97 samples over 24 families, mean 4.04 samples per family, with the bootstrap seed recorded alongside the interval. CAPE asserted at least one technique on every sample, so this is a predictor rather than an artefact of an empty one. The intervals are at the family level because our first version of this table was not, and the difference is not decorative: resampling samples rather than families gave an F1 interval 2.32 times narrower, on data whose intra-cluster correlation is 0.692. The row count is 97 and the count that supports an inference is 31.2.

And here is what the pipeline adds to it. On the 13 samples that completed both arms of the paired study of Section 5.1, the only samples where pipeline and baseline have been run on the same inputs, all three scored per sample against the same ground truth by the same code:

Table 3: Pipeline against the engine it is built on, like for like.

	mean F1	95% cluster CI
CAPE alone, no language model	0.1130	[+0.0654, +0.1624]
pipeline, static evidence only	0.1130	[+0.0770, +0.1543]
pipeline, with the sandbox report	0.1160	[+0.0823, +0.1485]

n = 13 samples over 8 families. Paired, because every sample went through both: +0.0030 F1, 95% cluster CI [−0.0353, +0.0344], exact cluster sign-flip p = 0.9609, better on 7 of 13.

Three analyst agents, a negotiation loop, a revision pass, an LLM judge and a weighted corroboration cascade land within +0.0030 F1 of the signature engine they are built on top of. Two of the means agreeing to four decimal places is a coincidence, and was checked rather than reported. The samples differ individually in both directions. The system is not reproducing the sandbox's answers; it reaches different answers of the same quality.

The interval on that difference is what should be read, not the point. At 8 families this design could detect a difference of 0.085 F1 at 80% power, and it did not detect one. That is a bound on the pipeline's contribution, not a demonstration that the contribution is zero.

Why the cohort is 97 and not 100. It was submitted as one batch and the sandbox reported every task complete. It had not been, and the timings split with nothing between the modes: the 43 tasks whose reports survived ran 186 to 366 s while 56 ran under a second, all 56 of them still marked `reported` with no report directory. Re-submitting the same binaries two days later produced full-length analyses on the same instance and recovered 54 of them; the remaining 3 are gone and all 3 are *still* marked `reported` at zero seconds. We had originally recorded this as reports that ran and expired, which was the comfortable reading of `Reports directory does not exist` and was wrong. A completion status from this instrument is not evidence that anything happened, which is why the retrieval path now checks each analysis's wall-clock duration before accepting its report (Section 6.1.5).

Points are means over per-sample F1 and bars are 95% intervals resampling the cluster the observations are independent at, recomputed from the retained per-sample records with the seed fixed. The two panels deliberately do not share an axis. An earlier version put all five arms on one scale, where a no-LLM baseline

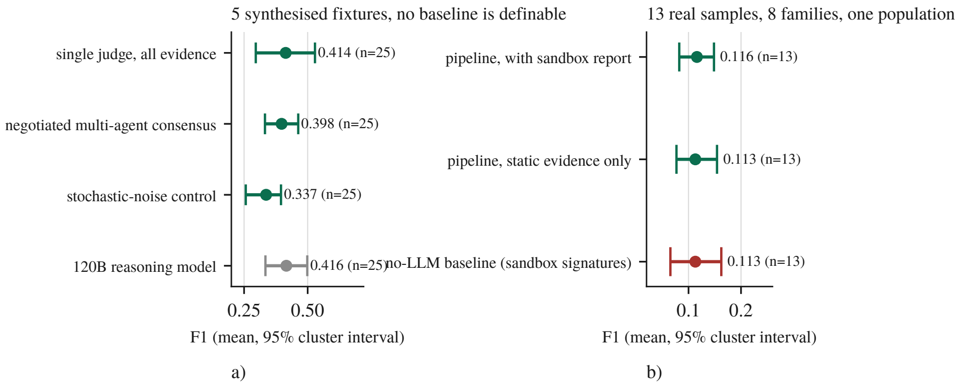

Figure 1: Every measured arm on one F1 axis. a) the synthesised fixtures, b) the real-sample population.

near 0.1526 beneath treatment arms near 0.4136 read as a large pipeline win. It is not one, because panel a)'s arms run on 5 synthesised inputs whose evidence is generated from their own technique lists and are scored against per-sample truth, while the baseline runs on real binaries scored against family-level truth. No baseline is definable for panel a) at all, since a deterministic regular expression over the dictionary that generated its evidence scores 1.000 there by construction. Panel b) is the comparison that can be made, and its three intervals overlap.

5.2. Multi-agent consensus does not pay for itself at equal budget

Design after Bertalanič & Fortuna. Three arms at an equal total token budget, including a stochastic-noise control in which one analyst receives irrelevant evidence.

Table 4: The equal-budget consensus arms.

arm	mean F1	rows	samples
single judge, all evidence at once	0.4136	25	5
negotiated multi-agent consensus	0.3975	25	5
noise control	0.3366	25	5

Here n is rows, while the unit that supports an inference is the sample, of which there are 5.

Paired delta, negotiated − single: −0.0161, 95% cluster CI [−0.1247, +0.0819], an interval containing zero, at 3.2× the tokens. At 80% power this design could have detected a difference of 0.223 F1; the observed difference is two orders of magnitude smaller than that. The null is a bound on what the design could see, not a demonstration that the two arms are equivalent.

Earlier drafts read the noise control's separation as proof that the harness can detect a difference when one exists, and it does not carry that weight. The control moves by −0.0770, [−0.1337, −0.0233], every one of the 5 samples in the same direction, but the effect is *below this design's own minimum detectable effect* of 0.120 and the exact cluster permutation test returns p = 0.0625, the smallest p the design can produce, because at 5 clusters the two-sided sign-flip test floors at 0.0625. The honest statement is that all 5 samples moved the same way, which is worth reporting and is not a demonstration of sensitivity. This was pre-registered as the experiment that would decide the paper's framing, and the literature's prior ran the same way: debate consumes more tokens for equal or lower accuracy on open-weight models of our size [39], and a second study reports a crossover at α=0.7 on our own model class [38] [preprint].

5.2.1. The same three arms on real binaries, where the design can see

The null above is a statement about a corpus that cannot produce a significant result. We re-ran the three arms on 24 real samples, one per malware family, so that every cluster holds a single observation and the family count is the cluster count. At 24 clusters the sign-flip floor is 0.00005 rather than 0.0625; above twenty clusters the assignments are sampled rather than enumerated, and the method is reported with each p.

Table 5: The consensus arms on real binaries.

arm	F1	output tokens	× single	calls
single judge	0.0967	39,986	1.00	1
negotiated consensus	0.1503	110,395	2.76	4
noise control	0.1498	94,388	2.36	4

Scored against the same family-level MITRE ground truth as the no-LLM baseline, so the F1 values are comparable to Table 3 and not to the fixture table above.

Both multi-agent arms beat the single judge, and neither beats the other. Negotiated minus single is +0.0537, 95% cluster CI [+0.0362, +0.0714], q = 0.0001, better on 19 of 24 families. The noise control minus single is +0.0532, [+0.0235, +0.0833], q = 0.0040. The two differences are the same difference.

The contrast that isolates the mechanism returns nothing, and this time that means something. Negotiated minus noise is +0.0005, [−0.0294, +0.0312], q = 0.9751. This design resolves 0.046 F1 at 80% power, and the effect the negotiation would have to carry, the +0.0537 its neighbours show, is above that resolution. A null below its own minimum detectable effect says nothing; this one is not that. If the negotiation were doing the work, this design would have seen it.

What separates the multi-agent arms from the single judge is therefore the thing they share; 4 model calls instead of 1, at 2.76× and 2.36× the output tokens. Spending more calls on a sample helps; making them argue does not. That is a claim about this pipeline at this budget on this corpus, and it is the claim the noise control was added to make possible. A control that separates from the treatment is a control that has done nothing, and this one does not separate.

The fixture corpus gave the opposite sign, which is the sharpest evidence we have about that corpus. There the noise control ran −0.0770 against the single judge and was worse on every sample in the same direction. Here it runs +0.0532 and is better, at the same q as the negotiation. Nothing about the arms changed between the two runs; the evidence did. A corpus whose inputs are generated from its own answer key does not merely have less power than one of real binaries. It can rank the arms the other way round.

5.3. A model 3.4 times larger does not separate from the local one

Same five fixtures, same prompt, same 2,400-token output budget:

Table 6: Local against frontier, same fixtures, same nominal budget.

arm	model	mean F1	rows	samples
local	Qwen3.6-35B-A3B (IQ3_K_R4)	0.4136	25	5
frontier	Nemotron-3-Super-120B-A12B	0.4162	25	5

Both arms see the same fixtures at the same repeats, so the comparison is paired:

> frontier − local = +0.0026, 95% cluster CI [−0.1322, +0.1460], 25 rows over 5 samples. The frontier model is better on 12 and worse on 13.

A 3.4× larger reasoning model, given the same evidence and the same nominal output budget, lands within three thousandths of F1 of a 35B model quantised to run on one desktop GPU, and its direction across samples is a coin flip.

That null is a bound and not a claim of equivalence. This design could detect 0.300 F1 at 80% power, coarser than every architectural effect reported here and coarser than the largest configuration effect we found, so it says nothing about the +0.0026 it returned.

The two arms were also not configured alike. The local arm runs with its reasoning stream disabled, necessarily, because the local server otherwise returns an empty answer, while the frontier arm ran with reasoning on and spent 56.5% of its budget there, so the nominal budget was equal and the budget available for an *answer* was not. A third endpoint measured later on the same fixtures bounds what that costs: with reasoning enabled it spent 99.9% of every call's budget thinking and scored 0.0000 across all 25 calls, and with reasoning disabled the same model scored 0.4501, so the flag is worth +0.4501 F1, [+0.3604, +0.5437], the largest effect measured on any arm in this paper. The frontier arm was not crippled that way, having parsed 25 of 25, so the null is not an artefact of a collapsed arm, but it is not the single-variable comparison it appears to be.

The matched arm cannot be built on that endpoint, and we established this by measurement rather than by assumption. Re-running the 120B arm with the reasoning parameter set, the provider accepted it and ignored it: 56.2% of the output was still reasoning against 56.5% without it, and the arm returned 0.4149 where the first run returned 0.4162, a paired Δ of −0.0014 at 95% cluster CI [−0.0695, +0.0799].

The re-run replicates the original configuration rather than correcting it. The confound is a property of the endpoint, and we report the null with it stated rather than promising a cleaner version.

A matched comparison is available on different weights, and it bounds two things at once. The model we run locally, `qwen3.6-35b-a3b`, is also hosted by its vendor at full precision on an endpoint that does honour the flag. Against our local 3-bit deployment, on the same fixtures and repeats:

Table 7: The same weights at two precisions, with and without the reasoning flag.

arm	reasoning	mean F1	paired vs local	95% cluster CI
local, IQ3_K_R4 (3-bit)	off	0.4136	,	,
vendor-hosted, full	off	0.3507	−0.0629	[−0.2133, +0.0963]
vendor-hosted, full	on	0.0080	−0.4056	[−0.5232, −0.2880]

Paired against the local arm; intervals resample samples.

Two results follow, and the first is weaker than we first wrote it. We cannot detect a quantisation penalty, and we cannot rule out a large one: the paired difference is −0.0629 with an interval of [−0.2133, +0.0963], which admits a penalty of up to 0.2133 F1 against our local deployment, and this design's minimum detectable effect is 0.331. What the data support is that 3-bit quantisation is not *demonstrably* this pipeline's handicap, not that it is not one. Second, the reasoning flag replicates at +0.3427 paired ([+0.2008, +0.4936]) on a second model, this time the one we host, with 24 of 25 calls exhausting the output budget on reasoning. The flag is the only effect in this paper that exceeds its own design's minimum detectable effect (0.310 here, 0.200 on the third endpoint). The largest effect we have measured on any arm is a configuration flag, not an architecture and not a parameter count.

Two qualifications belong with that, because it is the paper's one positive result. The flag comparisons are post-hoc, run after the confound was discovered rather than planned, and are corrected as a family of 5, at which their q-values are 0.1042 and 0.1042. And like every comparison on this corpus they sit at the exact test's floor of 0.0625. They are reported as sign-consistent across all 5 samples with an effect several times their detection threshold, which is the strongest statement this design can support and is not a claim of significance.

We report the frontier null because the literature's prior predicts otherwise, parameter size being the *only* statistically significant predictor of ATT&CK-classification F1 on the nearest task at ρ=0.85, p=0.014 [49] [preprint]. We do not reproduce that here and cannot test it as a series either, because a rank correlation over model size needs the arms matched on the flag worth more than the size effect and the only endpoint above 35B does not permit that match, leaving two configuration-matched arms that are both 35B.

An earlier version of this arm reported 0.5025 and was wrong to suggest a lead. That figure came from n=9, the run having been cut short by a daily request quota, and the apparent advantage did not survive completing the sample. It is the exact failure mode Section 4.3 warns about, and we caught it by finishing the run rather than by any insight. The completed run parsed 25 of 25 calls with no refusals and 1 hitting the output cap.

Where the larger model's budget went: across the 25 calls, 56.5% of output tokens were reasoning, and on a one-token answer, 84%, at 92 output tokens, 77 of them thinking. An equal-budget comparison must therefore cap *total* output including reasoning; capping content alone would hand the reasoning model roughly twice the generation for the same nominal budget, and the null above would have been a win bought with tokens.

5.4. Three independently built retrieval components, all near-inert in production

This is the paper's most replicated result, and it is negative.

Table 8: Three retrieval components, each measured in isolation and again end to end.

component	works in isolation?	contribution end to end
ATT&CK case-prior RAG	*self-consistency* 0.620 against a 0.424 frequency prior, scored on the corpus's own prior attributions rather than on MITRE ground truth	loses to the frequency prior in production (0.111 vs 0.123, MITRE ground truth)
family-feature RAG	yes, recall@5 0.199, 6.3× chance, leakage-free split	+0.0029 F1, precision −0.0088, n=19
opcode-hash attribution	n/a, never fires	0 of 18 samples; 7,716 functions hashed, 0 matches

Every one works where it was built and moves nothing where it is wired in, and the three fail for three different reasons.

The first row needs one qualification before the pattern can be read: its isolation figure is *not* accuracy, because the leave-one-out corpus is labelled with the pipeline's own prior attributions, so scoring the index against it measures agreement with its own upstream. It is reported because the comparison survives that. A frequency prior scored the same way on the same labels reaches 0.424, so the index carries information beyond base rates even under its own labelling, and the production column beside it is scored against MITRE ground truth on held-out samples, which is the number the conclusion rests on.

Each was built separately, each is defensible in design, and each is inert once wired to real inputs. The mechanisms differ, which is what makes the pattern worth reporting rather than three disappointments. The first fails on vocabulary mismatch between query and corpus, visible only in the score distribution while top-k accuracy stayed healthy; the second is simply small; the third fails for two independent reasons. Its corpus holds 3 samples under 2 generic labels, and the 8-instruction floor that correctly excludes thunks leaves 9 of 18 real samples with one hashable

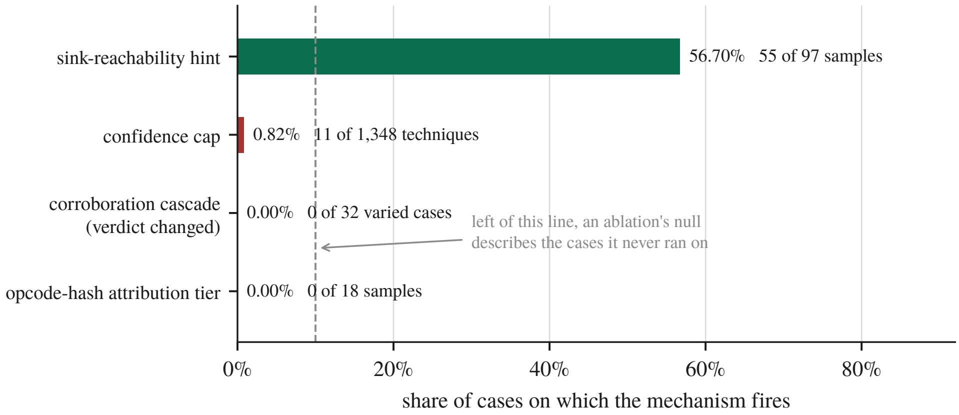

Figure 2: Firing rate decides whether an ablation can be read at all.

function or none, a sharply bimodal distribution that populating the corpus would not fix.

5.5. Mechanisms measured before their effects

A recurring finding is that a mechanism's *firing rate* determines whether its ablation can be interpreted at all.

Table 9: Firing rate before effect.

mechanism	fires on	consequence
confidence cap (falsification-before-confidence)	0.82% of techniques	an ablation would measure nothing; the null is uninterpretable
sink-reachability priority hint	56.7% of samples (55/97)	an ablation is interpretable, was run, and returned a null (Section 5.8)
STIX integrity pass	measured over 60 fresh judge bundles	reported by removal reason

A mechanism's ablation can only be read where the mechanism runs, and two of these run too rarely for an ablation to say anything.

Three of the four mechanisms the architecture was built around engage on almost nothing, so an ablation of any of them would return a null describing the cases where the mechanism never ran, for the reason Section 4.4 gives. Only the sink-reachability hint clears a rate at which an ablation would carry information, which is why it is the one we ablated, and Section 5.8 reports the null it returned.

5.6. The corroboration cascade does not reach the verdict

The multi-layer corroboration set is the design's central claim about evidence quality. We remove one Layer-0 source at a time and compare the bundle the analyst receives against the bundle produced with all of them, under two conditions that differ in exactly one respect, whether the removed source was the sole owner of its techniques.

Table 10: The corroboration cascade under two conditions.

condition	what removing a source does to the evidence	verdict changed	Jaccard vs all-sources
disjoint	its techniques disappear; nothing else claims them	32/32	0.750 [0.714, 0.800]
overlap	its techniques survive under a partner source, but their corroboration changes	0/32	1.000 [1.000, 1.000]

Both counts follow from the reconciliation step rather than from the judge, which is why they are arithmetic rather than evidence.

Take a technique away and the bundle loses it. Leave the technique in place and destroy the cross-domain agreement behind it, the thing the cascade exists to compute, and the bundle is byte-identical. The cascade runs, weights each source by a trust coefficient and reports a corroborated set in the run summary, and none of that reaches the artefact the analyst is given.

The reason is not the one we first wrote, and the correction is M5 of Section 6. The judge is not what makes the bundle behave this way. The reconciliation step drops every `attack-pattern` whose technique ID cannot be resolved and appends every cascade technique missing from the bundle, so the cascade's set is a guaranteed subset of every bundle the system emits whatever the judge produced. Recomputing each arm's cascade set from the same seeded fixtures shows the bundle is exactly that set in 80 of 80 arms, with the judge contributing zero techniques to any of them. Both rows of the table then follow from set arithmetic: under overlap the cascade's set is unchanged so the bundle cannot change, making 0 of 32 a necessity rather than a measurement of restraint, and under disjoint the removed source's techniques leave that set so the bundle must shrink, at 32 of 32. The Jaccard of 1.000 with a zero-width interval was the tell we missed, because across 32 ablated arms at temperature 0.1 a language model does not agree with itself that exactly.

The architectural conclusion is unchanged and, if anything, sharper. Corroboration does not reach the analyst's artefact, but the reason is not that a model overlooked it. The judge cannot subtract from the bundle's technique set and across 80 arms it added nothing to it, since omissions are restored by reconciliation and additions would have survived.

We stated that bound rather than the stronger claim it invites, because the evidence could not distinguish a judge whose output was unusable and wholly replaced from one that reproduced the cascade's set exactly. That measurement has since been taken, by intercepting the reconciliation step and recording what the model produced before the deterministic set was merged in. On the four calls that reached it:

Table 11: What the judge contributed to the artefact the analyst receives, intercepted at the reconciliation seam.

	total	per call
attack-patterns the judge emitted	50	12.5
carrying a resolvable ATT&CK ID	12	3.0
dropped, the model named no technique	38 (76.0%)	9.5
IDs the cascade did not already hold	0	0.0
injected because the judge omitted them	87	21.8

Counts are techniques, over four calls.

Three of the four calls produced nothing nameable at all; the fourth named twelve techniques, every one already in the cascade. Three quarters of the model's own attack-patterns asserted a behaviour it could not map to a technique and were discarded. Of the two pipelines the bound allowed, the evidence points at the second. The bundle is the cascade's set wearing the judge's name.

And half the calls never reached that step. Four of the eight timed out at the verdict ceiling, and on a timeout `give_verdict` returns a text-fallback bundle that never calls the reconciliation routine, so the cascade is not consulted on that path at all. The timeouts are not a property of the fixtures: the judge's 8,192-token output cap was renamed by our client library to a parameter the local inference server does not read, so the model decoded unbounded until the caller gave up (Section 6.1.8, M7). One such call was measured at 30,155 generated tokens and was still going.

Repeating the study with the cap fixed turns the pair into a controlled experiment, and the result inverts the section's own conclusion. With the ceiling binding, the same four fixtures fail and the same four succeed; the judge's share of the bundle is 0.0% in both conditions; every number on the reconciled path is identical. What changes is only how the failure arrives, 8,192 tokens of unparseable output in three and a half minutes, instead of a ten-minute timeout.

But the artefact is not the same. The fallback builder scrapes ATT&CK IDs from two places. The evidence claims, and the model's own raw response. In the uncapped condition that response is the literal string `[TIMEOUT]` and contains no IDs, so the fallback bundle was exactly the evidence-derived set, identical to the cascade set on all four calls. In the capped condition it is 18,748 to 24,710 characters of degenerate decode, and:

The last column is the set no evidence source corroborated.

47 techniques reach the analyst that the corroboration cascade never held, and none goes the other way. On one sample the bundle doubles. Because the uncapped run is a control whose raw text provably contains no IDs, every one of them is attributable to the model's own output. They passed through no filter at all. Not the

Table 12: Techniques reaching the analyst on the text-fallback path against those the corroboration cascade held, per fixture.

fixture	fallback	cascade	only in fallback
`jhuhugit`	32	20	**12**
`sardonic`	27	25	**2**
`sliver`	46	23	**23**
`wannacry`	26	16	**10**

cascade, not the reconciliation step, not the invalid-ID filter, not the integrity pass.

They are also, checked against the 691-technique ATT&CK catalogue, real; 45 of 45 unique IDs exist, none is invented. That removes the easy reading. The pipeline is not emitting hallucinated identifiers a schema check would catch. It is emitting genuine ATT&CK techniques that no evidence source claimed and no corroboration supports, in the same object type and the same bundle as techniques three independent sources agreed on, with nothing downstream to tell them apart.

So the finding that opened this section needs its scope stated exactly. The judge has no influence over which techniques reach the analyst on the path where it works. On the path where it fails it has more influence than on the path where it succeeds; 0 of 99 techniques when reconciliation runs, 47 of 131 when it does not. The architecture suppresses the model's contribution precisely when the model is functioning, and admits it precisely when it is not.

This replaces an earlier version of the same result, and the replacement is why we trust it. The first pass varied three of six Layer-0 sources over fixtures carrying five techniques and reported the verdict unchanged in 0 of 15 cases. Two defects were found in it afterwards: the absent sources included the Sigma layer, which fires on 94 of 97 samples at weight 0.55, above every static layer that study did vary, and at five techniques over six sources the round-robin assignment left one source with nothing, so its arm matched the baseline by arithmetic rather than by measurement. The re-run uses fixtures of 12 to 51 techniques so every source carries at least three claims, includes the Sigma layer, and adds a corroborated pair that does not involve YARA. The null survives all of it, at 32 arms rather than 15.

One pre-registered prediction resolved in both directions. Removing the tool-artifact layer should change nothing, because it emits on YARA's cascade domain and cannot contribute corroboration. Under overlap that is exactly right at 0 of 8, and under disjoint it is wrong at 8 of 8, because there the source solely owns its techniques. The prediction holds precisely where corroboration is the only thing varying, which is the sharpest evidence we have that the two conditions measure what we claim. Two further Layer-0 sources are absent from these arms by measurement rather than by choice, for the reason Section 8.6 reports.

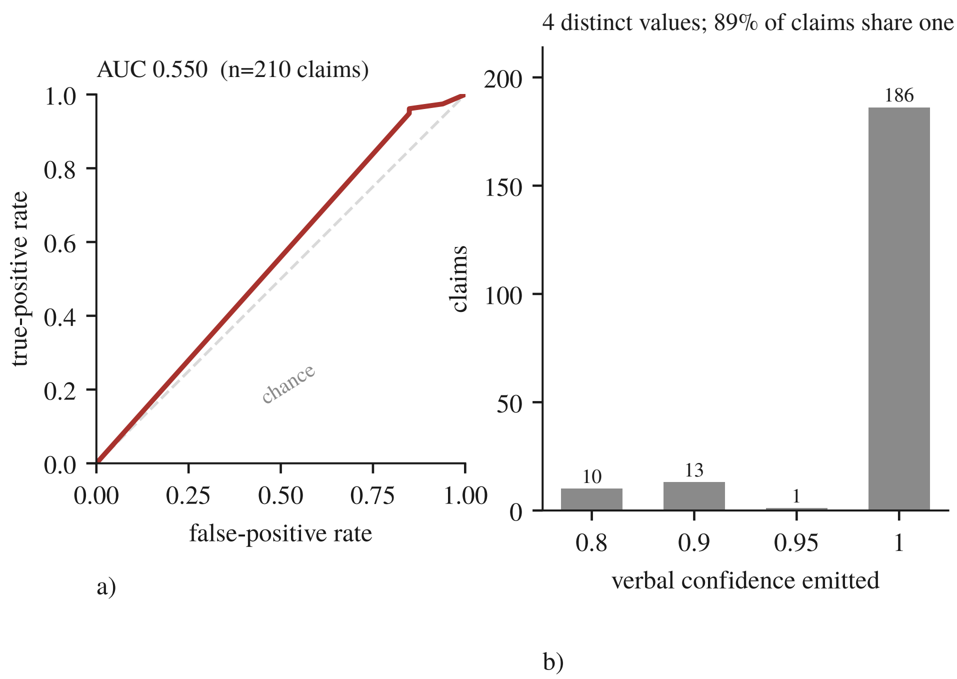

Figure 3: The number the gates consume barely orders anything. a) the ROC against resolved ground truth, b) the confidence actually emitted.

5.7. Confidence is nearly a constant

Verbal confidence, which the cascade and the deterministic gates consume, discriminates correct from incorrect claims at AUC 0.550, near chance, and is concentrated on 4 round values. Resampling samples rather than claims puts the interval at [0.475, 0.671], which contains chance, and 3 of the 5 samples sit at or below chance individually, with the pooled figure carried by the one that reaches 0.778. This matches `arXiv:2606.29490`'s finding that verbal confidence measures willingness to commit rather than correctness, and it means every deterministic gate keyed to that number is keyed to noise.

Panel a) is the ROC over 210 claims scored against resolved ground truth, and panel b) shows why it is nearly the diagonal. 186 of those 210 claims carry confidence exactly 1.0, so the score has almost no ordering to contribute. The estimate is rank-based with ties averaged, which for this distribution is not a detail. Sorting the tied claims arbitrarily instead returns 0.458, and the difference between the two numbers is entirely an artefact of how 89% of the data is handled.

5.8. What the ablations cost, and what that revealed

The one mechanism whose firing rate justified an ablation (Section 4.4, 56.7%) was ablated, paired, on the subset where it fires. It does nothing measurable:

Units differ per row and are named in the row.

Table 13: The sink-reachability hint, paired on the samples where it fires.

outcome	mean Δ (hint on − off)	95% CI
distinct technique IDs	+0.50	[−3.33, +4.50]
claims	−0.83	[−4.33, +3.67]
seconds	+52.55	[−161.93, +268.45]

n=6 pairs; the hint is better on 2, worse on 2, and tied on 2, with per-pair deltas of +9, +4, 0, 0, −4, −6, large in both directions and cancelling. This is the fourth architectural claim to end in a null, and the last one we were in a position to test.

The result that constrains the result. Half the experiment was not scoreable. Twelve pairs were attempted and six survived screening.

Table 14: Every sample excluded from the paired study, with the reason and the count.

excluded	n	why
degenerate decode	3	an arm emitting 49 to 117 claims across 2 to 14 technique IDs, ratios 8.4 to 34.3
unattributable	2	both arms dead, and the host state needed to decide whether the pipeline or the machine failed was never recorded
incomplete	1	an arm exceeded the 630 s bound, a genuine outcome, but it costs the pair

A 50% pair-loss rate bounds what any ablation on this pipeline can detect. An effect smaller than the noise from losing half the samples is not measurable here, and quoting +0.50 [−3.33, +4.50] without that context would claim a precision the instrument does not have. Reporting the loss rate beside the estimate is the whole of what we have to say about how to read it.

The two `unattributable` pairs are this paper's own Section 4.6 recurring against it. The run halted at 10 of 24 arms, and they died while the host's swap file was exhausted and the model server had 2.3 GB of its own address space paged out; one arm then exceeded a 594-second budget on a prompt trimmed to 16,000 characters, which is inexplicable for a model generating from RAM and unsurprising for one generating from disk. We had retained per-sample outputs, as our own rule requires. What went unrecorded was the environment the measurement ran in. The harness now captures `MemAvailable`, `SwapFree` and the server's resident-versus-swapped split at both ends of every arm and the scorer screens on it, forward only, never for data already collected.

Three arms failed outright; two were re-run and one deliberately was not. Two carried a `Connection error` from a restart race, meaning the measurement never happened, and were re-run. The third was the 630-second timeout, which is an outcome. Deleting an outcome one dislikes is selection rather than repair. The recovered pair contributed a −4, against the hint.

Running it, however, surfaced a production defect that the test suite (2,753 passing) did not: on any binary rich enough to exhaust the 40-step ReAct budget, the analyst returned zero techniques, because the salvage path received a fresh copy of a budget it was already inside. Fixed and verified on the same sample, from 1,677 s to 323 s and from 0 to 5 technique IDs. The fix is partial. One sample still exceeds the bound, and the server's own timings show generation varying from 162 to 20 tokens/s on this hybrid recurrent architecture, so a bounded input does not rescue a case where the tokens themselves are eight times slower than assumed.

5.9. Summary

Of the four architectural claims this system was built around, all four are now measured and every one is negative or near-null. None is left pending sandbox access. The cascade closed on the recovered cohort and the attribution tier's remaining half fired on 0 of 18 samples. What survived measurement is not the architecture but the account of measuring it.

6. Instrument Failures

An LLM analysis pipeline is mostly other people's servers. Ours calls a reverse-engineering server for disassembly, a sandbox for detonation, a vector store for retrieval, and a model server for inference, over three protocols. Each boundary is a place where a request can succeed and still not mean what the caller assumed.

This section reports seven such failures. We report them together because they share a shape that a test suite is poorly positioned to catch and a results table cannot show. The instrument answered successfully, and answered about something else. The last three are ours rather than someone else's server, two of them in the analysis code that produces our results and one in the pipeline that produces the artefact. That is the point. The shape does not stop at the network boundary, and it does not stop at the evaluation harness either.

6.1. Seven mechanisms

6.1.1. M1. An unset argument arrives as an assertion

The sandbox's MCP interface declares 36 tools. Every one takes an optional `token` parameter with a declared default of `""`. Our client built its argument model with "required, else `None`", and the agent framework fills every declared field before invoking. So an argument the agent never mentioned reached the server as an explicit null, and a field typed `str` rejected it:

```
1 validation error for call[verify_auth]
token
  Input should be a valid string [type=string_type, input_value=None, ...]
```

All 36 tools failed. *Unset* and *null* are different statements, and the client was making the second while intending the first.

Why it survived to first contact. The reverse-engineering server, the only one this client had ever talked to, declares no optional parameter with a typed default, so the same malformed argument dictionary happened to be acceptable there. A defect in shared client code was invisible because only one of the two servers it served had ever been exercised.

6.1.2. M2. A load that does not change what the server is looking at

`load_program` imports a binary and answers `{"success": true, "program": "<name>"}`. Every caller read that as "the server is now looking at this binary". The server maintains a separate notion of the current program, and `load_program` sets it only when nothing is current yet:

```
load A        -> {"success": true, "program": "A"}   current: A
load B        -> {"success": true, "program": "B"}   current: A   <-- still A
run_analysis  -> {"program": "A", "new_functions": 0}
call graph    -> A's graph, byte-identical, for every sample
```

From the second sample of a container's lifetime onwards, everything derived from it described the first binary while the report named the current one. That covered the decompilation, the imports, the strings, the call graph and the function hashes. The response even contained the correct program name, which is what made it convincing.

6.1.3. M3. A refusal wearing a success

The same server answers a load it cannot perform with HTTP 200 and an error in the body:

```
{"error": "Failed to load program from: /data/samples/x.exe"}
```

`raise_for_status()` sees nothing wrong. Downstream code then analysed and described whichever program remained current. When the server began refusing loads after roughly thirty in one lifetime, 66 consecutive samples produced a call graph of exactly 75,426 characters before anyone noticed.

6.1.4. M4. Two bounds composing into an empty result

The analyst's ReAct loop has a 40-step budget; exceeding it triggers a salvage that re-invokes the model to synthesise from what was gathered. That salvage received a fresh copy of the full time budget, so loop-plus-salvage exceeded the hard cap by construction. On any binary rich enough to exhaust the step budget the analysis returned zero techniques, at a cost of 28 minutes:

```
loop completed: 19 tool calls, 41 messages, elapsed 109.5s
ended without a final answer ... forcing synthesis
static no-tools fallback exceeded the 1530s hard cap
```

Neither bound was wrong alone. Exceeding the first *guarantees* an attempt at the second, and the composition was never considered.

6.1.5. The same mechanism at a fifth boundary, caught before it produced data

M1 through M4 were all found after the fact, in data already collected. The fifth was not, and the difference is the whole argument of this paper.

Fetching the sandbox cohort's reports, we found that a request for a report the sandbox has since deleted is answered with HTTP 200 and a 63-byte body:


```
{"error":true,"error_value":"Reports directory does not exist"}
```


Fifty-six of one hundred tasks answer this way. A fetcher that trusted the status code would have written fifty-six of those bodies into the archive under the filename of the sample they were supposed to describe, and the three studies reading that archive would each have scored them. It did not, because the fetcher verifies the report's own `target.file.sha256` against the identifier it asked for before writing anything, a check that exists only because M3 taught us the shape. This is the first time the discipline paid forward rather than backward, and it cost four lines.

We first recorded the consequence as a retention limit, that the reports had existed and expired. That explanation was wrong, and finding out how wrong is the fifth failure. Asking the sandbox how long each analysis had taken produced a split with nothing between the modes: the 43 tasks whose reports survived ran 186 to 366 s and the other 56 ran under a second, all 56 of them still marked `reported`. A Windows PE does not detonate in one second. Nothing had expired; nothing had happened, and the instrument said otherwise. Re-submitting the same binaries two days later produced full-length analyses on the same instance, recovering 54 of the 56 and putting the cohort at 97. The remaining 3 produced no report on either attempt and none of them failed, all 3 being *still* marked `reported` at zero seconds with no report directory.

The lesson generalises past this instrument. A completion status is a statement about a queue rather than about an analysis, and it is exactly as trustworthy as an HTTP 200. The retrieval path now reads each task's wall-clock duration and refuses anything under 60 s, an order of magnitude below the shortest real analysis here, before it will accept a report.

6.1.6. M5. An ablation that measured a code path and reported a language model

The four above are failures of other people's servers. This one is ours, it is the most recent (2026-08-14), and it is the only one that reached a results table.

We ablated the corroboration cascade by removing one evidence source at a time and comparing the STIX bundle the analyst receives, and wrote the two conditions of Section 5.6 up as a finding about the judge model, that it attends to the list of claimed techniques and ignores the evidence-quality apparatus above it. The judge was not involved. A deterministic reconciliation step drops unresolvable attack-patterns and appends every cascade technique missing from the bundle, so the cascade's set is a guaranteed subset of every bundle whatever the model produced, and both of our numbers are necessities of an `if` statement rather than measurements of restraint. The experiment could not have returned anything else.

The architectural conclusion survives the correction and the mechanism does not. A second study, already written and about to run, was designed to compare a weighted cascade against a flat union of the same claims; both of its arms would have shared one reconciliation set, so it would have reported no difference after an hour of computation, correctly and vacuously. It was stopped four minutes in by the same log line that exposed M5.

What made this one hard to see is that the tell was in the results the whole time. A Jaccard of 1.000 with a zero-width bootstrap interval across 32 ablated arms at temperature 0.1 is not something a language model produces; it is what a constant looks like. We read it as an unusually clean null, because a clean null was the result we were prepared to find.

6.1.7. M6. A configuration difference wearing a parameter count

The most recent (2026-08-14), and the only one whose wrong answer agreed with the literature.

We assembled a parameter-size series to test a published finding that parameter count is the only significant predictor of ATT&CK-classification F1 (ρ=0.85 [49] [preprint]). The harness read every completed arm file, ranked mean F1 against total parameters, and reported ρ=+0.866, reproducing the prior almost exactly, across a 3.4× span, with the confounds it could not remove printed honestly beneath.

The five rows were three models, one appearing twice because it had been run in two configurations and another twice because it had been run twice. The duplicate configurations were not a labelling detail: the same weights score 0.3507 with the reasoning stream disabled and 0.0080 with it enabled, because 24 of 25 calls then spend their entire output budget reasoning and never answer, and the 0.0080 row sat at the small end of the parameter axis where it set the sign. What the series measured was a flag, ordered by coincidence against size.

The failure is not the duplicate rows but that the arm-selection rule did not exist. The harness had careful arithmetic, with averaged ranks so file order cannot break ties, an exact permutation p because four points cannot reach significance, and a common-cell restriction so endpoint availability cannot masquerade as model size. Every one of those guards was about a way the *numbers* could mislead, and none was about whether the rows were comparable in the first place.

The rule now keys on the measured reasoning share of each arm rather than the flag the harness requested, because those two disagree. One provider accepts the parameter and ignores it, so an arm selected on intent would enter the series labelled matched while running the opposite configuration. With the rule applied, two arms qualify and both are 35B, so the series refuses and says which arm was excluded and at what measured reasoning share. Nine unit tests pin the rule.

What made this one hard to see. It agreed with the published result. M5 was caught by a number too clean to believe; this one produced a number in exactly the range a reader would expect, in the direction the literature predicts, with its limitations already stated. There was nothing anomalous to notice. It was caught by reading the arms table under the correlation and asking why one model was on it twice, which is a question no result, however wrong, would have prompted.

The phenomenon is not ours. Under a strict output-length constraint the ordering of models by capability does not hold [7], and our reasoning flag consumes the answer budget, which makes the disabled arm a brevity-constrained arm under a different name. M6 is a domain instance of that rather than a new phenomenon, and what we would add sits in the remedy: Section 2 states the protocol difference, that matching on the requested configuration is not sufficient when a provider accepts a parameter without acting on it.

6.1.8. M7. A safety property that was configured, documented, and never sent

The last one is in the production pipeline rather than in an evaluation harness, and it removed a guarantee the code states in its own comment.

The judge is built with an 8,192-token output ceiling, and the line that builds it says why; *"Bound the verdict generation so a degenerate decode can't consume the full wall-clock timeout."* The client library renames that parameter to the API vendor's newer spelling when it serialises the request, and our local inference server does not read the newer spelling. It accepted the field, ignored it, and decoded without a ceiling.

Measured on one call: a 1,403-token prompt, 30,155 tokens generated, still generating at 46 tokens per second when the caller's ten-minute wrapper gave up. The only thing that ever stopped a verdict was wall-clock.

The consequence is not a slow call. Four of eight fixtures in a separate study never returned a verdict at all, and for each of them the pipeline emitted a bundle through its text-fallback path, which does not run the reconciliation step, so the corroboration cascade contributed nothing and the analyst received techniques copied straight from the raw evidence claims. A component we describe as bounded was unbounded, and its failure mode was to hand the analyst a differently-built artefact without saying so.

It was invisible because the configured value was correct at every level anything reads. The container passed it, the model object held it, and it survived every later rebinding intact; only the serialised request was wrong, and nothing in the system reads the serialised request. Every check anyone would think to perform would have confirmed the property that did not hold. What found it was neither a test nor a review but a study measuring something else, which recorded *which branch* each failed call took rather than only that it failed. Four calls named the timeout branch, which prompted the question of why a temperature-zero model would need ten minutes, which led to the server's own log and a token counter past thirty thousand. The instrumentation that caught it had been written for a different question three hours earlier.

The incompatibility itself is known and the consequence is what we contribute. `llama.cpp` #8634 [53] [preprint] reports that "the limit is respected when requesting a chat completion, but for non-chat ones, the model keeps generating tokens forever (until ctx-len is reached)" and has been open since July 2024, while `vLLM`

#11976 [54] [preprint] asked for a server-side cap and was completed in February 2025, so one of the two has since closed the gap and we say so rather than leaving the impression that both remain open. What one costs inside a measurement is the part we report: a documented safety property silently absent for as long as it has existed, and half of a study's calls diverted onto a bundle-construction path that skips the corroboration cascade entirely.

6.2. *Why the test suite did not help*

2,753 tests passed throughout. This is not a gap in test quality but in test *shape*.

M2 and M3 require a second case within one server lifetime, and a unit test loads one program, asserts, and tears down; the state that goes wrong is created by the second call and cannot exist in a single-call test. M1 required a second *server*, and the behaviour was correct against the only server exercised. M4 required a rich enough input, since the composition only appears when the step budget is exhausted, which small fixtures never do.

The last three failed differently, because every unit involved behaved as specified. M5's `_reconcile_with_cascade` has unit tests that assert exactly what it does, and the function was never wrong; what was wrong was an experiment that varied the cascade's input and attributed the output to a model downstream of it, and no test of a component can catch a misattribution made three modules away. M6 was tested more carefully than anything else in the harness and the tests were about the wrong question, since every guard concerned a way the numbers could mislead and none asked whether the rows entering the correlation were comparable, that having been assumed where the arms were assembled rather than decided anywhere a test could see. M7 had nothing left to assert on: a unit test would check that the output ceiling is 8,192 and it is, at every level the object model exposes, because the defect existed only in the serialised request, which no test inspects and no application code reads.

Preconditions such as a second call, a second server or a large input are exactly what a fast unit suite is designed to avoid. The last three are worse than avoided, they are invisible to unit testing in principle, because the defect lived in the composition, in which measurement was attributed to which cause or in which representation of a value crossed a boundary.

6.3. *What did find them: output cardinality*

Five of the seven were found by the same observation, a number that repeated where variation was expected. M6 and M7 were not, because their outputs vary and there is no repetition to notice; M6 was caught by reading the arms table under the correlation and M7 by a study that recorded which failure branch each call took.

M5 extends the detector where the idea is least comfortable, because there the repeated number was our own result rather than a server's response and the variation that failed to appear was the model's. A perfect agreement is the same signal as an identical digest and deserves the same suspicion.

Table 15: What the output-cardinality check saw and which defect each observation turned out to be.

observation	defect
a priority hint of exactly 2,575 characters for two unrelated binaries, and a third in an earlier session	M2
call graphs identical to the character (404,337 chars, 11,798 lines) for samples of 241 KB and 139 KB	M2
66 consecutive samples at exactly 75,426 characters	M3
every tool call returning the same validation error	M1
a 25-minute call that always produced one claim and zero techniques	M4
a Jaccard of 1.000 with a zero-width interval across 32 ablated arms at temperature 0.1	M5

The generalisation is one line of arithmetic. Before trusting a batch measurement, ask how many distinct outputs the N inputs produced; if far fewer than N differ on a dimension that should vary, such as output length, digest or element count, the instrument is repeating itself, and repetition is what stale state looks like from outside. It needs no ground truth and no oracle, which is what makes it usable exactly where correctness is hard to check.

Plot distinct outputs against inputs processed and a healthy instrument tracks the diagonal while a stuck one goes flat, so the diagnosis is in the shape and no ground truth is required. Panel a) is measured, at 63 distinct call-graph sizes across 97 samples, its staircase's flat treads being genuinely identical binaries rather than a fault, and that is the figure we now report beside every batch result. Panel b) is a schematic, and the reason is the argument of Section 6.4: it depicts M3, the run in which 66 consecutive samples returned a byte-identical 75,426-character call graph, and we cannot plot it because that run predates the per-sample retention policy those very failures caused us to adopt. The curve this paper turns on is the one we are unable to draw.

This is a refinement rather than a discovery, and Section 2.6 places both the detector and the genus in the literature that already carries them. All four boundary mechanisms fall inside that genus. M5, M6 and M7 share its meta-pattern but not its setting, since no server misled us and no protocol was involved, and the taxonomy's classes each describe a call to something else.

6.4. What it cost

A completed study is withdrawn from this paper. A seven-year 210-sample temporal-drift analysis ran the full pipeline per sample against a long-lived server that was never restarted between samples, M2's precondition exactly, and whether

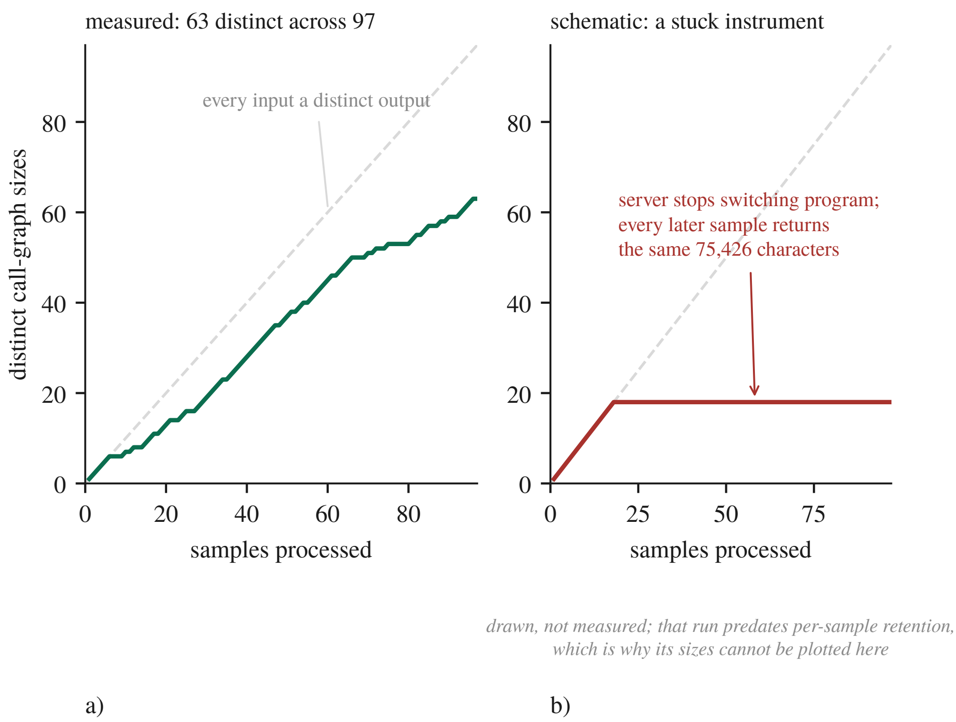

Figure 4: The whole detector, drawn. a) a measured run, b) a schematic of a stuck instrument.

it was affected cannot be determined because its per-sample outputs were not retained. The result had passed review, entered the claim ledger as novel, and was cited internally for weeks.

Two policies follow and both are cheap. The first is to retain per-sample outputs for every study, because the withdrawal is caused not by the defect but by the defect *plus* the inability to re-ask the question afterwards, and aggregates cannot be re-interrogated. The second is to restart the shared server between samples. In our sweeps this recovered 12 of 14 samples previously recorded as unmeasurable; the failures belonged to the *state they inherited*, not to the samples, and fresh state per sample removes a whole class of the failures above.

6.5. The claim we are making

Not that silent failures exist at tool boundaries, which is documented. Ours is narrower: three mechanisms at three distinct integration boundaries, in argument encoding, server-side session state and HTTP status versus body, plus one from composing two local safety bounds; the setting, an evaluation pipeline where the failure propagates into a published claim rather than into a support ticket; and a detector run alongside results rather than as a test, because the failure appears in the batch and not in any single call. M5 and M6 extend that from other people's servers misleading you to the same shape occurring wherever a measurement's cause is assigned rather than measured, and M7 shows the shape is not peculiar to evaluation, because there the artefact the analyst receives was affected rather than a number in a table.

7. Discussion

7.1. What a null means at this cluster count

The most consequential thing we can say about our own negative results is that most of them are bounds rather than equivalences, and that we did not know this when we first wrote them down. Five of the studies reported here run on a corpus of five samples, and at five clusters the exact two-sided cluster permutation test cannot return a value below 0.0625, so no comparison measured on that corpus can reach $\alpha = 0.05$ whatever its effect size. That is a property of the design and not of the data, and no amount of extra decoding repeats moves it, because repeats add rows inside clusters and rows inside clusters are not what the test counts. Multiplicity correction is therefore beside the point there. We apply Benjamini-Hochberg over two declared families and it finds nothing to correct, because there was nothing at $\alpha = 0.05$ to begin with.

The practical consequence is that a null has to be reported with its resolution. Our frontier comparison could detect 0.300 F1 at 80% power and returned +0.0026. Both facts are true and only the pair of them is informative, since the second alone reads as equivalence and the first alone reads as a failed experiment. This also changes what the cheap fix is. The instinct on seeing an underpowered paired design is to add repeats, because repeats are cheap and samples are expensive, and on clustered data that instinct is exactly wrong: a sixth fixture would have halved the attainable p, while a sixth repeat on five fixtures moves it not at all.

7.2. Where a measurement's cause is assigned rather than measured

The literature we counter-searched against locates silent failures at the boundary between modules, and four of our seven crossed such a boundary while three crossed none. What the seven share is not a boundary but an attribution. An ablation varied the deterministic reconciliation step and we attributed the difference to a language model; a rank correlation ordered a reasoning-configuration flag and we attributed the ordering to parameter count; a documented output ceiling was renamed during serialisation and we attributed boundedness to a component that had never once been bounded. In every case the number was real and the arrow pointing to its cause was drawn by us.

We offer that as a proposal rather than a taxonomy, since seven cases from one project is not a class and the published taxonomy is built on a corpus we cannot match. But it does suggest a different question to ask of an evaluation than boundary-oriented thinking suggests. Not whether any component failed silently, but, for each number about to be reported, whether its cause was measured or assigned. The correction described in Section 4.3 is that question turned on ourselves and answered badly: every interval in an earlier draft attributed its width to sampling variation among independent observations, the observations were not independent, and nothing in the pipeline, the tests or the review caught it because the defect was never in a function.

7.3. *What a practitioner should take from the negatives*

We are wary of drawing implementation advice from one pipeline on one machine, so this is narrow. Measure the firing rate before the effect, because a mechanism that engages on 0.82% of its inputs produces an ablation whose null describes the cases where it never ran; this is the cheapest practice in the paper and it changed which experiments were worth running rather than merely how they were reported. Count the distinct outputs, because that needs no ground truth and no oracle, which is what makes it usable where correctness is hard to check, and it belongs beside the sample size in a report rather than inside a test. And retain per-sample outputs, then ask what else the study is made of: we adopted retention after losing a study to its absence, the rule was scoped to the object under study, and the next failure was in the environment, where four arms died on host memory and we had their outputs but not the host state. The rule you write after a failure is scoped to that failure.

7.4. *What we are not in a position to say*

We can say something narrower than "multi-agent decomposition does not help" and sharper than the fixture null. On 24 real samples it does help, by +0.0537 F1 over a single judge, and a noise control helps by the same +0.0532, with the two separated by +0.0005 at a resolution of 0.046. So the decomposition into several calls is worth something here and the negotiation between them is not, at this budget, on this corpus, with this model. What we cannot say is that negotiation is worthless in general, because a control that matches the treatment tells us where our gain came from and not where anyone else's must.

We cannot say that model capacity is not the ceiling. We can say that a 3.4× larger model did not separate from ours at a resolution of 0.300 F1, that the two arms differed in a configuration flag worth more than any architectural effect we measured, and that the endpoint would not let us remove the difference. We cannot say that verbal confidence is uninformative in general. We can say that in this pipeline it ranks correct claims above incorrect ones at AUC 0.550 with an interval containing chance, so the deterministic gates keyed to that number are keyed to something we cannot distinguish from noise. And we cannot say that our seven mechanisms generalise. What we can say is what each of them cost.

8. Threats to Validity

We organise this section around the nine pitfalls of *Chasing Shadows*, which surveyed all 72 peer-reviewed LLM-security papers of 2023 and 2024 [41] and found every one exposed to at least one, with only 15.7% discussing any [41]. We add two checks the survey does not have, both of which caught errors in this work. Where a pitfall is genuinely closed we say so; where it is not, we say what remains rather than what we intend.

8.1. The threat that materialised

Most threats sections describe hazards. This one begins with damage. One study is withdrawn, a seven-year 210-sample temporal-drift analysis that was completed and had entered our claim ledger as a novel result. It drove the full pipeline per sample against a long-lived Ghidra server that was never restarted, which is the precondition for Section 6.1.2's defect, and its per-sample outputs were not retained, so whether it was affected cannot be determined. The result is not restated anywhere in this paper.

Section 6 reports all seven mechanisms with the layer each occurred at, four of them at a boundary with another server and three inside our own code. We report them here because the interesting threat to an LLM-plus-tooling pipeline is not that the model is wrong. It is that the instrument answers a different question than the one asked, convincingly.

8.2. The nine pitfalls

Four of the nine need more than a row. On P6, truncation enters through chunking at function boundaries, a per-call evidence cap, a 40-step ReAct budget, an 8,192-token verdict cap and a 400-char hint cap, and two findings belong here rather than in the row. The enumeration of truncation sites was itself incomplete: a 20,000-edge cap on the call-graph fetch was discovered only while instrumenting a different measurement, and it silently truncates 1 of 97 samples, so we describe how our list was built rather than presenting it as exhaustive. And bounds compose. Exceeding the step cap guarantees an attempt at the time cap, and on rich binaries that attempt could not finish, two limits producing an empty result between them; removing a hint made the judge overrun a 600 s ceiling and return an empty bundle 6/17 times.

P8 is the pitfall this work is most exposed to and the one where the evidence has moved. A 120B reasoning model has now run to completion on the same fixtures, repeats, prompt and token budget, and did not separate from the local model, at paired ΔF1 +0.0026, 95% cluster CI [−0.1322, +0.1460], n=25, better on 12 and worse on 13 (Section 5.3). A 3.4× parameter advantage producing no measurable difference is evidence against the pitfall's usual worry rather than merely an absence of evidence for it. An interim version of that arm reported 0.5025 at n=9 and read as a lead, and completing the sample moved the estimate through the local mean and out the other side; the arm had been truncated by a daily request quota rather than by anything about the samples, and this audit carried the wrong number for a day.

That null is confounded and the confound cannot be removed on that endpoint. The local arm runs with its reasoning stream disabled while the 120B arm ran with reasoning on, spending 56.5% of its output budget there. We re-ran it with the flag set and the provider accepted the parameter and ignored it, at 56.2% reasoning and F1 0.4149 against the original 0.4162, a paired Δ of −0.0014 at cluster CI [−0.0695, +0.0799]. The re-run replicates the arm rather than correcting it, and no further re-run will do better because the control is not exposed. What is being confounded is

Table 16: Our exposure to each of the nine pitfalls, with the basis for the verdict.

pitfall	verdict	basis
P1 data poisoning	`CLEAR`	nothing is trained; retrieval corpora are curated and their provenance documented
P2 label inaccuracy	`CLEAR`	ground truth is MITRE-curated and no LLM scored any result, a standing constraint rather than an outcome; no human analyst rated any report either
P3 data leakage	`PARTIAL`	one instance found by us, disclosed and mitigated, but never systematically audited; the model's training data is unknown to us and memorisation was not probed
P4 model collapse	`CLEAR`	augmenting the long-term memory corpus with LLM-generated cases was considered and refused, with a cited rationale
P5 spurious correlations	`PARTIAL`	two were found and are reported; no systematic perturbation testing was performed
P6 context truncation	`EXPOSED`	truncation is designed in throughout and the counters now exist, but the distribution over a full cohort does not
P7 prompt sensitivity	`PARTIAL`	a structured prompt-variation study exists, but production prompts are fixed and were not varied per model; our own single-run parsed-claim count is prompt sensitivity surfacing as measurement error
P8 surrogate fallacy	`PARTIAL`	every local result comes from one model on one machine, and a second endpoint has now run to completion against it
P9 model ambiguity	`PARTIAL`	model and engine are pinned by digest, revision and commit, but the commit was reconstructed rather than recorded

not small: on two separate models the same flag is worth 0.34 and 0.45 F1, the only effect in this paper that exceeds its own design's minimum detectable effect.

Quantisation is no longer an unmeasured threat under P8 either. The model we run locally is also hosted by its vendor at full precision on an endpoint that does honour the reasoning flag, and paired on the same fixtures the vendor's hosting of the same weights scores −0.0629 F1 against our 3-bit `IQ3_K_R4` deployment, 95% cluster CI [−0.2133, +0.0963] at n=25, an interval containing zero and a point estimate pointing away from the direction the threat assumes. Two serving stacks differ alongside the precision, so this bounds the deployment rather than quantisation alone, but the specific worry that a 3-bit local model understates what these architectures can do is not supported. What P8 cannot close is the size series, for a measured rather than a budgetary reason: testing a parameter-size trend needs three arms at three sizes matched on the flag that outweighs size, the one endpoint that honours the flag hosts the same 35B model we already run, and the one above 35B does not honour it. Run once before that constraint was enforced, the correlation returned ρ=+0.866 and would have agreed with the literature for the wrong reason. Coverage also remains: the second model has been measured on five synthetic fixtures rather than on the malware cohort, and the free tier's 50 requests/day makes that a two-day run or a paid one.

P9 is `PARTIAL` for one reason. The running binary reports its version as `unknown`, and the engine commit was recovered from a vendored copy of the sources and proved against an identical 837-file source list rather than read off the artefact. Build provenance must be captured at build time; ours was reconstructed, and we say so.

8.3. Two checks the survey does not include

Both were added after they caught errors here, and both are described as practices in Section 4. The first is to diff the claim register against the evidence log. All nine pitfalls concern the relationship between claims and experiments, and the failures it caught sat one level below that, needing no literature search but only two of our own documents read against each other. A project disciplined enough to keep both a findings log and a claim ledger has, by that fact, created the conditions for the two to diverge. The second is the output-cardinality check of Section 6.3, which found every boundary defect and which we now report alongside results at 63 distinct call-graph sizes across 97 samples.

8.4. Could the label have leaked into the evidence?

A scored component that derives its output from the same source as the labels is scoring a tautology. We tested this component by component rather than assuming it, and report the result including the part that is unflattering. Ground truth is the MITRE `malware uses attack-pattern` relationship set, built from the public ATT&CK STIX distribution and resolved to a sample through its family signature, so it comes from MITRE and from nothing this project produces.

Three components are clear. The Sigma layer reads the technique identifier from each rule's own `attack.tNNNN` tag, and those rules are community-authored detections with hand-written tags, so Sigma shares ATT&CK's vocabulary with the labels and not their source; there is no path from a family label into a rule tag. The sandbox baseline, which is the one that would have mattered most, takes its identifiers from class attributes hand-written in each signature module and mapped through the sandbox's own table, consulting no family attribution anywhere, which is precisely what makes it a valid baseline rather than a second view of the answer. And the retrieval corpora do not overlap the evaluation cohorts, checked by digest rather than by assertion: of the 1,733 cases in the ATT&CK case corpus, none shares a sha256 with the 100-sample dynamic cohort or with the 210-sample drift manifest.

One construct problem survives and it is ours. The case corpus is labelled with the technique identifiers the pipeline itself previously attributed, so scoring the index against those labels measures agreement with its own upstream rather than accuracy. That number is relabelled as self-consistency in Section 5, and the conclusion rests on the production figure beside it, scored against MITRE ground truth on held-out samples. There is also one shared vocabulary, named rather than hidden: the catalogue defining valid technique identifiers is the same file that bounds the label universe, so the invalid-identifier rate is measured against the catalogue the labels are drawn from. A prediction can be catalogue-valid and wrong, which is the whole of what that metric claims, but a reader is entitled to know the two come from one build.

8.5. Construct validity: what the ground truth can and cannot support

Per-sample ground truth is family-level MITRE `uses`, which is coarse. A single Emotet binary need not exhibit all ~47 techniques catalogued for Emotet, and a packed sample exhibits fewer still, so absolute recall carries a structural ceiling and precision carries noise. We accept two consequences rather than argue with them. Absolute F1 values here are not comparable to work using per-sample expert labels, and the bias is approximately constant across arms, so within-study contrasts are the defensible reading, which is exactly why a baseline matters. The sandbox alone, with no LLM anywhere, scores F1 0.1526 [+0.1114, +0.1998] on our cohort of 97. Every pipeline figure is read against that rather than against zero, and on the samples where both have run the full pipeline is +0.0030 F1 above it.

8.6. The dynamic channel is two-thirds constant

Any claim about what the sandbox contributes has to survive one measurement of what the sandbox reports. Across the 97 archived analyses there are 143 distinct network domains and 38 of them appear in every single sample, the analysis VM's own vendor telemetry, present in each capture whatever was detonated. Per sample, between 55.9% and 79.2% of observed domains are cohort-ubiquitous, median 67.9%. So two-thirds of the network evidence in a dynamic arm is the instrument describing itself. A treatment that constant is weaker than its name suggests, and an effect attributed to malware behaviour may be partly an effect of the VM's idle traffic, which is why we report the ubiquitous share alongside every dynamic-versus-static contrast rather than in a footnote.

The same measurement bounds two Layer-0 sources from the other direction. The LOLBin and DGA layers produced a claim on none of the 95 reports archived when that ablation ran, while being fed a median of 8,667 recorded API calls and 48-−68 domains respectively. They are offered the evidence and decline it, which is why neither appears as an arm in the cascade ablation, since giving a mechanism an equal share of ground truth when it never engages would measure a system that does not exist. An earlier version of this measurement, on the 43 analyses that survived before the cohort was recovered, gave 130 domains with 40 ubiquitous at a median share of 71.4%. More than doubling the cohort moved the figure by three points and left the conclusion where it was.

8.7. The host as an uncontrolled variable

A threat we did not anticipate and met late. The machine a measurement runs on is part of the instrument. Our working set does not fit a 31 GiB host alongside an interactive session, with the model server holding ~16 GB, the analysis worker ~8 GB and the disassembly container up to 6 GB. During a paired ablation the swap file was exhausted and the model server had 2.3 GB of its own address space paged out; an arm then exceeded a 594-second budget on a prompt trimmed to 16,000 characters. Whether that arm failed because of the pipeline or because of the host cannot be determined, because we recorded the pipeline's outputs and not the host's state. The affected arms are reported as `unattributable` rather than as failures, and the ablation as incomplete rather than as a null.

Three things follow. Wall-clock bounds are host-dependent measurements wearing the costume of a system property, so any result here that turns on a timeout is a statement about this pipeline on this machine under whatever load it had. The retention rule we adopted after the first failure did not cover this one, because Section 4.6 says to retain per-sample outputs and we did, but the rule was written about the object under study and what went unrecorded was the environment the study ran in. And a screen for this can only be applied forward, since arms already collected without host state cannot be re-screened, which is the same structural problem that withdrew our drift study appearing in a new variable.

A postscript, because it took three attempts to see. Two of the interruptions above we attributed to memory pressure and treated with progressively better limits, a floor, then a strike counter, then an allowance for declared allocations, then marking the model server as the kernel's preferred OOM victim. All four were correct and none was the cause. The harness had started the server as a child process, so it ran inside the cgroup of the terminal that launched it and its memory was accounted to that scope; the kernel's log named the scope plainly and we did not read it until the third failure. Every fix we made chose *which process* the kernel would kill, and the defect was *whose accounting it was killed inside*. It is the same error as M1 through M4 in a different register: a mechanism that looked like it was working, an intervention that addressed a real thing at the wrong layer, and a log line that had contained the answer for two days.

8.8. Five objections

We wrote down the five strongest objections we could raise against this paper and then answered them, or failed to and said so.

The first is that the central experiment's corpus is generated from its own answer key. The equal-budget consensus comparison, the frontier comparison and the confidence calibration all run on 5 synthesised fixtures whose evidence is assembled by walking each fixture's ground-truth technique list and emitting one hand-written sentence per technique, so evidence and answer key are in bijection, and a deterministic regular expression over the dictionary that produced that evidence scores F1 1.000 on 5 of 5. We concede it, and it changes what those arms are for. They are a pilot that isolates one variable at a time under conditions where nothing else can move, which is worth something for a mechanism question and nothing for an accuracy claim, and we report no accuracy claim from them; the pipeline's accuracy is stated only against the no-LLM baseline on real samples in Table 3. The corpus also bounds inference in a way no amount of collection inside it would relieve, since at 5 clusters the exact two-sided cluster permutation test cannot return a value below 0.0625 and repeats add rows inside clusters while the test counts clusters. What settled it was running the same three arms on 24 real samples, one per family (Section 5.2.1), and the answer went against the fixture version: on real binaries the noise control runs +0.0532 against the single judge where on fixtures it ran −0.0770. The same control and the same arms, opposite signs. A corpus generated from its own answer key did not merely have less power here; it ordered the arms the other way round. Two of the three arms are therefore no longer a pilot, and the frontier comparison and confidence calibration still are.

The second is that the system does not beat its baseline, so the component analysis is uninteresting. On the samples where both were run the full pipeline scores 0.1160 against the sandbox's own signature mapping at 0.1130, a paired difference of +0.0030, [−0.0353, +0.0344]. We answer it only partly, because the inference is not valid in the direction the objection runs: an end-to-end null does not entail component-level nulls, and two of the components measured here are not inert but *suppressed*, since the corroboration cascade is computed and then discarded at the reconciliation step, which is a mechanism finding that would hold at any end-to-end score. Where the objection does land is on what the paper is for. It is not a systems paper, the architecture did not survive its own evaluation, and a reader who wants a system that beats its baseline will not find one here.

The third is that one of the retrieval numbers is self-consistency rather than accuracy. The ATT&CK case-prior index is reported as working in isolation at F1 0.620 against a 0.424 frequency prior, but that evaluation is leave-one-out over a corpus of 1,733 cases whose labels are the pipeline's own prior attributions. We concede it and have relabelled the number as self-consistency. It is retained rather than deleted because a frequency prior scored the same way reaches 0.424, so the index carries information beyond base rates even under its own labelling, and because the production number beside it is scored against MITRE ground truth on held-out samples, where the index loses to the prior at 0.111 against 0.123. That second number is the one the paper's conclusion rests on. We also ran the leakage check the objection implies rather than asserting disjointness, and no sha256 in the case corpus appears in either evaluation cohort, so the construct problem is the labelling and not overlap.

The fourth is that the judge findings rest on four calls. The result that the judge supplies 0 of 99 techniques when it works, and that 47 uncorroborated techniques reach the analyst when it fails, is measured on four judge calls. We concede the sample size and defend the design, which are different things. The intercept patches the reconciliation seam and the text-fallback builder and records every technique crossing each, so it requires a live judge call per observation, and four is what the quota and the host allowed. What the four support is narrower than the sentence they are usually quoted in. On the working path the finding is deductive rather than statistical, because the reconciliation step restores the cascade's set by construction and the 80-arm mechanism check confirms the bundle equals the cascade set on every arm, with the judge contributing one of its own on 0 of 8 samples, an upper bound of 0.375 on the per-sample rate. On the failing path it is an existence claim: uncorroborated identifiers do reach the analyst, demonstrated on four calls against an uncapped control whose raw text provably contains none. Neither claim is a rate. What would settle it is the same intercept over the 97-sample cohort, which needs no new instrumentation, only the host.

The fifth is that seven defects in your own code is a post-mortem rather than a result. This is the one we can least answer and we do not claim the category. Every mechanism was counter-searched in an adjacent field's vocabulary before being claimed and the search demoted more than it confirmed, so what we assert is narrower than a class: a setting where the artefact of such a failure is not a degraded user session but a measurement that is wrong and looks right, and a price paid rather than hypothesised. Two things we cannot show. We cannot show these recur in other teams' pipelines, because we have one pipeline. And we cannot show the detector generalises, because it found four defects retrospectively, on batches we already had reason to distrust; the prospective test, reporting output cardinality beside every batch for a year and counting how many defects it catches before anything else does, is the experiment and we have not run it.

The objections that remained open were blocked by the same thing, a host on which the model server does not fit alongside anything else. Section 8.7 reports the environment as an uncontrolled variable that cost four arms of a completed ablation, and it is the reason this paper's weakest results are weak. Lifting the first objection shows what that takes. The blocker was never the method; it was that the server's resident set climbs with cumulative requests and does not come back down, at 10.4 GB loaded and 18.1 GB after 60 minutes, unreclaimable, so a long run walks the host into its own memory guard. Cycling the server from the checkpoint between stretches of work turned a run that could not finish into one that did, which is a change to the method and not to the machine. The judge objection is still open and needs the same treatment applied to a more expensive intercept.

9. Conclusion

We built a multi-agent LLM pipeline for mapping malware evidence to ATT&CK techniques and then spent longer measuring it than building it. Four architectural claims motivated the design, and measured at equal token budget against simpler alternatives none of them survived (Section 5). Negotiated consensus does not beat a single judge, the corroboration cascade never reaches the artefact, two-tier attribution fires too rarely to carry the result, and the confidence number every deterministic gate consumes is indistinguishable from chance. None of those components is broken and each was built for a reason we would give again, but they do not move the end-to-end result, and we report that as a result rather than as a tuning opportunity. The one place where a corpus large enough to produce a significant answer was available, the decomposition into several calls turned out to be worth something and the negotiation between them nothing, which is a more specific failure than the fixture null could express.

Those negatives are readable only because firing rate was measured before effect. A mechanism that engages on a small fraction of its inputs produces an ablation whose null describes the cases where it never ran, and knowing that changed which experiments were worth running at all. It is the cheapest practice in this paper. The second condition on readability is resolution: most of these nulls are bounds rather than equivalences, and each is reported with the minimum detectable effect of the design that produced it.

The finding we did not expect to be the paper is that the instrument was repeatedly wrong in ways that looked like data. Seven mechanisms are catalogued in Section 6 with the layer each occurred at. Four crossed a boundary with another server and each returned a plausible result rather than an error; a suite of 2,753 passing tests caught none of them, and all four were found instead by one arithmetic check on how many distinct outputs the inputs produced. Three crossed no boundary at all, and those share a different shape. No server misled us. In each case a measurement's cause was assigned rather than measured, which we offer as a proposal rather than as a taxonomy, on seven cases from one project.

We are careful about what is new. Silent failure at tool boundaries is documented, the metamorphic relation behind the detector is ordinary, the genus has a published taxonomy, and inference-time configuration inverting model rankings inside a constrained budget is established. What we add is the setting and the price. In an evaluation pipeline the artefact of such a failure is not a degraded user session but a measurement that is wrong and looks right, and the price here was concrete: one completed study withdrawn because its per-sample outputs were not retained and the question can no longer be asked of it, then four arms of a later ablation lost the same way one level up, because the rule written after the first failure was scoped to that failure and the environment a study runs in is also part of the instrument.

We claim the measured negatives, the seven mechanisms with the layer each occurred at, the one-line detector that found four of them together with what found the other three, the selection rule that follows from a provider accepting a parameter without acting on it, and a no-LLM baseline of F1 0.1526 [+0.1114, +0.1998] at n=97, without which none of our F1 numbers refer to anything and against which the full pipeline gains +0.0030 F1. We do not claim that multi-agent decomposition cannot work, that these retrieval designs are worthless, or that our practices generalise beyond one system. This is one pipeline, one 35B model at one quantisation, on one machine, evaluated on Windows PE malware.

What we do assert is a change of default. In a pipeline assembled from other people's servers the correctness of the model is not the binding constraint on the correctness of the result. Long before a benchmark score is a claim about a system, it is a claim about an instrument, and a server that answers is not the same as a server that answered your question.

Declarations

Ethics and containment

Every sample analysed in this work is live Windows PE malware. The 97-sample cohort and the 210 dated samples of the withdrawn drift study were obtained from MalwareBazaar (abuse.ch) under its terms of use, which permit research redistribution of samples but not of the corpus as a package.

Detonation happens only inside a CAPE sandbox on a dedicated Windows guest image reverted to a clean snapshot between analyses. The sandbox host is reachable from one network segment and from no public route, holds no credentials for any other system, and shares no filesystem with the host that runs the pipeline. Binaries are held only in a directory excluded from the host's real-time scanner, are never committed to version control, and are not redistributed with this paper. We note a limitation of that arrangement rather than claiming it sufficient: the guest reaches the public internet during detonation, because a sample that cannot resolve its command-and-control infrastructure behaves differently from one that can and the network evidence channel would otherwise be empty for every sample. Live detonation with egress is the standard arrangement for behavioural sandboxing, and it is the arrangement whose consequences we report, including that the domains every sample contacted turn out to be the guest image describing itself.

No user study was conducted, no personal data was collected, and no human analyst scored any output. That last point is a limitation of the evaluation, stated as such in Threats to Validity, rather than a claim about ethics.

Data availability

The evaluation harnesses, the derivation of every number in this paper, the per-sample records they read and the scripts that build the figures and assemble the document are released with the paper. The archive holds every per-sample record retained by every study reported here, in the JSON the harness wrote, together with the offline re-analysis that recomputes every interval, design effect, minimum detectable effect and adjusted p-value from those records and its random seed, the ATT&CK ground-truth fixtures derived from the public `mitre-attack/attack-stix-data` repository under the ATT&CK Terms of Use, and the model digest and engine commit needed to reproduce the local arm.

Four things are withheld. Malware binaries are not released and are obtainable from the sources named in Background by the SHA-256 digests in the archive. Sandbox reports are not released in full because they embed strings and memory contents from the samples. The sandbox host's address appears nowhere in the archive and is referred to throughout as a private address. And one dataset used for retrieval-corpus construction is redistributed by its authors under terms that do not permit our redistribution, so it is referenced rather than included.

Not available. The 210-sample temporal-drift study's per-sample outputs do not exist. They were written to a path that was valid on the machine the harness was first written on and silently relative on the machine it ran on; the study is withdrawn on that account and the withdrawal is reported in Results rather than quietly repaired. The manifest of the 210 samples survives and is included, so the cohort can be reconstructed even though the results cannot.

Reproducibility

Two runs of the offline analysis over the released records produce byte-identical output, asserted by a test in the released suite rather than claimed here, and every interval carries the seed, the iteration count and the number of clusters it was computed from in the artefact itself, so an interval cannot be read without what is needed to reproduce it. The live arms are not bit-reproducible and we do not claim they are. Decoding is at temperature 0.1 on the local arm and at each provider's default on the hosted ones, one of which accepts a reasoning-configuration parameter and does not act on it. Anyone re-running them should expect the numbers to move and should read the intervals accordingly.

Use of generative AI

Large language models are the object of study in this work, so the pipeline under evaluation is built from them and every measurement reported here is a measurement of their behaviour in it. Separately, generative AI was used as an authoring and engineering aid, for drafting and revising prose, writing evaluation harnesses and their tests, and performing literature searches whose results were then verified by fetching each source. The verification is not incidental to this disclosure: of the nine citations added by those searches and checked one by one, three said something the source did not, one quoted for a sentence absent from the paper, one cited for a practice it does not describe, and one blending two incompatible published accounts into a single attribution. All three are corrected in the text and the corrections are recorded, because a search summary that reads as a citation is the same class of failure this paper is about. An internal readability assessment of report narratives was performed with a language model as a development aid; its results are deliberately excluded and no LLM scored any result reported here. The authors take responsibility for all content, including every number, every citation, and every claim about what the measurements support.

Competing interests

The authors declare no competing financial or non-financial interests. No external funding supported this work. All measurements were taken on hardware owned by the authors, except for calls to three commercially hosted inference endpoints,

which were paid for at their public list prices and whose providers had no involvement in, or advance knowledge of, this evaluation.

Data and sources

MalwareBazaar (abuse.ch), `https://bazaar.abuse.ch`, supplied the dated, family-labelled Windows PE samples analysed end to end; they are handled only in a scanner-excluded directory and are never committed. MABEL, the Malware Analysis Benchmark for AI/ML, features only at v2.10, mined offline into the family-fingerprint catalogue and the ATT&CK case corpus with no binaries downloaded. Ultimate-RAT-Collection supplied RAT builder and payload binaries for that catalogue and for the leakage-free retrieval evaluation's held-out split. Dike-Dataset was downloaded and assessed but not catalogued, its labels being coarse malice scores with no family or technique annotation. MITRE ATT&CK (Enterprise), `https://attack.mitre.org`, supplies the family-to-technique `uses` relationships used as per-sample ground truth, derived from `mitre-attack/attack-stix-data` under the ATT&CK Terms of Use.

References

[1] H. S. Gunawi, C. Rubio-González, A. C. Arpaci-Dusseau, R. H. Arpaci-Dusseau, B. Liblit, EIO: Error handling is occasionally correct, in: 6th USENIX Conference on File and Storage Technologies (FAST), 2008, measures error loss at module boundaries: 1153 of 9022 propagation channels (13%) drop an error code without handling it, and inter-module calls are a major cause.

[2] D. Yuan, Y. Luo, X. Zhuang, G. R. Rodrigues, X. Zhao, Y. Zhang, P. U. Jain, M. Stumm, Simple testing can prevent most critical failures: An analysis of production failures in distributed data-intensive systems, in: 11th USENIX Symposium on Operating Systems Design and Implementation (OSDI), 2014, an error handler that only logs the error is counted as ignoring it; 25% of catastrophic failures arise that way, and 92% from incorrect handling of errors that were explicitly signalled.

[3] A. Alquraan, H. Takruri, M. Alfatafta, S. Al-Kiswany, An analysis of network-partitioning failures in cloud systems, in: 13th USENIX Symposium on Operating Systems Design and Implementation (OSDI), 2018, pp. 51–68, "The majority of the failures were silent", and where a warning was returned "all returned warnings were confusing, with no clear mechanism for resolution".

[4] J. Xue, Y. Zhao, Y. Wang, J. Chen, D. Wang, A characterization study of bugs in LLM agent workflow orchestration frameworks, in: 40th IEEE/ACM International Conference on Automated Software Engineering (ASE), Industry Showcase, 2025, pp. 3369–3380, 1026 bugs across LangChain, LlamaIndex

and Haystack; nine root causes and six symptom categories. doi:10.1109/ASE63991.2025.00278.

[5] M. Liu, S. Zhong, W. Bi, Y. Zhang, Z. Chen, Z. Chen, X. Liu, Y. Ma, A first look at bugs in LLM inference engines, ACM Transactions on Software Engineering and Methodology929 bugs across llama.cpp, vLLM and four other engines; the taxonomy carries both "Incorrect Request Parsing" as a root cause and "Silent Error" as a symptom (2026). doi:10.1145/3788873.

[6] Y. Li, Z. Liu, P.-L. Poon, D. Towey, C.-A. Sun, et al., Metamorphic relation generation: State of the art and research directions, ACM Transactions on Software Engineering and MethodologyPreprint arXiv:2406.05397 (2024). doi:10.1145/3708521.

[7] Y. Sun, H. Wang, J. Li, J. Liu, X. Li, H. Wen, Y. Yuan, H. Zheng, Y. Liang, Y. Li, Y. Liu, An empirical study of LLM reasoning ability under strict output length constraint, in: Proceedings of the 2025 Conference on Empirical Methods in Natural Language Processing, 2025, pp. 7652–7671, finding 3: under strict output constraints reasoning performance "might not scale monotonically with the model size". Finding 4 independently covers our reasoning-flag confound: reasoning models do not always outperform instruction-tuned ones under the same constraint. doi:10.18653/v1/2025.emnlp-main.389.

[8] M. Mizrahi, G. Kaplan, D. Malkin, R. Dror, D. Shahaf, G. Stanovsky, State of what art? A call for multi-prompt LLM evaluation, Transactions of the Association for Computational Linguistics 12 (2024) 933–949, 6.5M instances over 20 models and 39 tasks: "different instruction templates lead to very different performance, both absolute and relative", and the relative part is the ranking. doi:10.1162/tacl_a_00681.

[9] T. Xu, J. Zhang, P. Huang, J. Zheng, T. Sheng, D. Yuan, Y. Zhou, S. Pasupathy, Do not blame users for misconfigurations, in: 24th ACM Symposium on Operating Systems Principles (SOSP), 2013, pp. 244–259, names the failure mode: "silent overruling refers to the case that the system changes an unacceptable user setting into the default value without notifying the user", measured across 74 parameters in Squid and Apache. doi:10.1145/2517349.2522727.

[10] W. Yu, et al., Maltracker: A fine-grained NPM malware tracker copiloted by LLM-enhanced dataset, in: Proceedings of the 33rd ACM SIGSOFT International Symposium on Software Testing and Analysis (ISSTA), 2024. doi:10.1145/3650212.3680397.

[11] W. Zhao, et al., AppPoet: LLM-based Android malware detection via multi-view prompt engineering, Expert Systems with Applications 262, arXiv:2404.18816 (2025).

[12] A. Rollinson, N. Polatidis, LLM-generated samples for Android malware detection, Digital 6 (1) (2026) 5. doi:10.3390/digital6010005.

[13] S. Saha, et al., MaLAware: Automating the comprehension of malicious software behaviours using LLMs, in: IEEE/ACM International Conference on Mining Software Repositories (MSR), 2025, arXiv:2504.01145.

[14] Center for Threat-Informed Defense, TRAM: Threat report ATT&CK mapper, Open-source software, MITRE Engenuity, not a paper and cited as the artefact it is; the repository names no preferred citation (2023).

[15] V. Legoy, M. Caselli, C. Seifert, A. Peter, Automated retrieval of ATT&CK tactics and techniques for cyber threat reports, in: 1st Cyber Threat Intelligence Symposium (CTI), 2020, arXiv:2004.14322. Recorded as a conference contribution by the University of Twente research portal; not indexed under this title in dblp.

[16] G. Husari, E. Al-Shaer, M. Ahmed, B. Chu, X. Niu, TTPDrill: Automatic and accurate extraction of threat actions from unstructured text of CTI sources, in: Proceedings of the 33rd Annual Computer Security Applications Conference (ACSAC), 2017, pp. 103–115. doi:10.1145/3134600.3134646.

[17] K. Satvat, R. Gjomemo, V. N. Venkatakrishnan, EXTRACTOR: Extracting attack behavior from threat reports, in: IEEE European Symposium on Security and Privacy (EuroS&P), 2021, pp. 598–615.

[18] Z. Li, J. Zeng, Y. Chen, Z. Liang, AttacKG: Constructing technique knowledge graph from cyber threat intelligence reports, in: Computer Security, ESORICS, 2022, pp. 589–609. doi:10.1007/978-3-031-17140-6_29.

[19] M. T. Alam, D. Bhusal, Y. Park, N. Rastogi, Looking beyond IoCs: Automatically extracting attack patterns from external CTI, in: 26th International Symposium on Research in Attacks, Intrusions and Defenses (RAID), 2023, pp. 92–108, the LADDER framework.

[20] A. Lekssays, U. Shukla, H. T. Sencar, M. Parvez, TechniqueRAG: Retrieval augmented generation for adversarial technique annotation in CTI text, in: Findings of the Association for Computational Linguistics (ACL), 2025, arXiv:2505.11988.

[21] F. Morbiato, M. Keller, P. Nair, L. Romano, Hierarchical retrieval augmented generation for adversarial technique annotation in cyber threat intelligence text, PREPRINT, not peer reviewed. arXiv:2604.14166 (2026).

[22] Y. Cheng, C. Li, R. S. P. Basuki, Q. Cui, W. Ding, P. Gao, TTPrint: Evidence-grounded TTP extraction via diverge-then-converge verification, PREPRINT, not peer reviewed. arXiv:2605.25836; the Comments field says so in as many

words. Kept because its evidence-grounding requirement is the design constraint our own gate obeys, so dropping it would let us appear to have set that bar ourselves (2026).

[23] M. Büchel, T. Paladini, S. Longari, M. Carminati, S. Zanero, et al., SoK: Automated TTP extraction from CTI reports, are we there yet?, in: 34th USENIX Security Symposium, 2025, pp. 4621–4641.

[24] K. D'Oosterlinck, O. Khattab, F. Remy, T. Demeester, C. Develder, C. Potts, In-context learning for extreme multi-label classification, PREPRINT, not peer reviewed. arXiv:2401.12178, v1 only, no Comments and no journal reference (2024).

[25] L. Lange, H. Adel, et al., AnnoCTR: A dataset for detecting and linking entities, tactics, and techniques in cyber threat reports, in: Joint International Conference on Computational Linguistics, Language Resources and Evaluation (LREC-COLING), 2024, arXiv:2404.07765. CC-BY-SA 4.0.

[26] A. Abdallah, J. Holdcroft, M. Ali, A. Jatowt, Are LLM-based retrievers worth their cost? an empirical study of efficiency, robustness, and reasoning overhead, in: Proceedings of the 49th International ACM SIGIR Conference on Research and Development in Information Retrieval, 2026, arXiv:2604.03676.

[27] H. T. Ng, et al., The CoNLL-2014 shared task on grammatical error correction, in: Proceedings of the Eighteenth Conference on Computational Natural Language Learning: Shared Task, 2014, cited with the BEA-2019 shared task for the $F_{0.5}$ convention, which weights precision twice recall to penalise overcorrection. The convention is documented by the shared tasks themselves.

[28] C. Bryant, M. Felice, Ø. E. Andersen, T. Briscoe, The BEA-2019 shared task on grammatical error correction, in: Proceedings of the Fourteenth Workshop on Innovative Use of NLP for Building Educational Applications, 2019.

[29] S. Welleck, I. Kulikov, S. Roller, E. Dinan, K. Cho, J. Weston, Neural text generation with unlikelihood training, in: International Conference on Learning Representations (ICLR), 2020, arXiv:1908.04319. Welleck et al. blame the likelihood objective itself; the training-data account is the other paper's.

[30] H. Li, T. Lan, Z. Fu, D. Cai, L. Liu, N. Collier, T. Watanabe, Y. Su, Repetition in repetition out: Towards understanding neural text degeneration from the data perspective, in: Advances in Neural Information Processing Systems (NeurIPS), 2023, arXiv:2310.10226. Argues that self-reinforcement explanations reduce to the training-data account.

[31] G. Chen, H. Sun, D. Liu, Z. Wang, Q. Wang, B. Yin, L. Liu, L. Ying, ReCopilot: Reverse engineering copilot in binary analysis, PREPRINT, not peer

reviewed. arXiv:2505.16366, v1 only, no Comments and no journal reference. Cited only as one of the open-weight binary specialists that establish the model-tier split (2025).

[32] H. Tan, Q. Luo, J. Li, Y. Zhang, LLM4Decompile: Decompiling binary code with large language models, in: Proceedings of the 2024 Conference on Empirical Methods in Natural Language Processing (EMNLP), 2024, pp. 3473–3487. doi:10.18653/v1/2024.emnlp-main.203.

[33] N. Jiang, C. Wang, K. Liu, X. Xu, L. Tan, X. Zhang, P. Babkin, Nova: Generative language models for assembly code with hierarchical attention and contrastive learning, in: International Conference on Learning Representations (ICLR), 2025, poster. arXiv:2311.13721.

[34] Z. Xuan, X. Xu, M. Zheng, L. Z.-H. Tan, J. Guo, T. Zhang, L. Yu, C. Wang, X. Zhang, Identifying adversary tactics and techniques in malware binaries with an LLM agent, PREPRINT, not peer reviewed. TTPDetect. arXiv:2602.06325. Kept because it is the nearest system to ours and the sentence citing it concedes ground rather than claims it; dropping it for want of a venue would let this paper imply it holds that ground itself. No peer-reviewed system with the same scope was found (2026).

[35] K. Kate, T. Pedapati, K. Basu, Y. Rizk, V. Chenthamarakshan, S. Chaudhury, M. Agarwal, I. Abdelaziz, LongFuncEval: Measuring the effectiveness of long context models for function calling, PREPRINT, not peer reviewed. arXiv:2505.10570, v1 only, no Comments and no journal reference. Kept because it says the tool-catalogue degradation we report is already documented in general, which is the direction that costs us (2025).

[36] V. Paramanayakam, A. Karatzas, I. Anagnostopoulos, D. Stamoulis, Less is more: Optimizing function calling for LLM execution on edge devices, in: Design, Automation and Test in Europe Conference (DATE), 2025, arXiv:2411.15399. Both quoted figures were confirmed against the full text.

[37] W. Li, S. Manickam, Y.-w. Chong, S. Karuppayah, PhishDebate: An LLM-based multi-agent framework for phishing website detection, in: IEEE International Conference on Big Data (BigData), 2025, pp. 6606–6615, arXiv:2506.15656. The published citation is given in the arXiv Comments field. doi:10.1109/BigData66926.2025.11401440.

[38] D. Tran, D. Kiela, Single-agent LLMs outperform multi-agent systems on multi-hop reasoning under equal thinking token budgets, PREPRINT, not peer reviewed. arXiv:2604.02460. Kept because it says our null is not the first of its kind, and because the crossover figure it reports for our own model class has no reviewed equivalent we could verify. Bertalanič and Fortuna reach the same conclusion in a reviewed venue (2026).

[39] B. Bertalanič, C. Fortuna, The cost of consensus: Isolated self-correction prevails over unguided homogeneous multi-agent debate, in: ACM Conference on AI and Agentic Systems, 2026, arXiv:2605.00914. doi:10.1145/3786335.3813137.

[40] D. Lea, J. Ghawaly, G. G. Richard III, A. Ali-Gombe, A. Case, REx86: A local large language model for assisting in x86 assembly reverse engineering, in: Annual Computer Security Applications Conference (ACSAC), 2025, arXiv:2510.20975.

[41] R. Evertz, N. Risse, C. Neuer, N. Müller, S. Normann, et al., Chasing shadows: Pitfalls in LLM security research, in: Network and Distributed System Security Symposium (NDSS), 2026, arXiv:2512.09549. Living appendix at llmpitfalls.org.

[42] J. Ng, A. Milani Fard, Evaluating retrieval-augmented generation for explainable malware analysis, in: ACM SecDev, 2026, poster. arXiv:2605.03140.

[43] J. Metz, L. F. D. de Abreu, E. A. Cherman, M. C. Monard, On the estimation of predictive evaluation measure baselines for multi-label learning, in: Advances in Artificial Intelligence, IBERAMIA, Lecture Notes in Computer Science, 2012, pp. 189–198, crossref types LNCS proceedings as book-chapter by convention; the container title is the IBERAMIA 2012 proceedings. doi:10.1007/978-3-642-34654-5_20.

[44] J. Metz, N. Spolaôr, E. A. Cherman, M. C. Monard, Comparing published multi-label classifier performance measures to the ones obtained by a simple multi-label baseline classifier, PREPRINT, not peer reviewed. arXiv:1503.06952, v1 only, no venue. Kept for its systematic-review finding rather than for the requirement itself, which now rests on the reviewed IBERAMIA 2012 paper by the same group (2015).

[45] A. Lazaridou, A. Kuncoro, E. Gribovskaya, et al., Mind the gap: Assessing temporal generalization in neural language models, in: Advances in Neural Information Processing Systems (NeurIPS), 2021, arXiv:2102.01951.

[46] O. Oyelayo, S. Abedu, S. Khatoonabadi, E. Shihab, Developer challenges in the adoption of model context protocol in AI agent development, in: 7th International Workshop on Bots and Agents in Software Engineering (BotSE), co-located with ICSE, 2026, pp. 53–59, bug reports and pull requests on MCP reference servers: data validation and type issues are the second most prevalent class at 13.97%. doi:10.1145/3786161.3788462.

[47] A. Martin-Lopez, S. Segura, A. Ruiz-Cortés, A catalogue of inter-parameter dependencies in RESTful web APIs, in: Service-Oriented Computing (ICSOC), 2019, pp. 399–414, across 40 APIs and over 2500 operations, input dependencies are “the norm, rather than the exception, with 85% of

the reviewed APIs" having them, and OpenAPI cannot express them. `doi:10.1007/978-3-030-33702-5_31`.

[48] S. Dev, A. Sloan, J. Kavner, N. Kong, M. Sandler, Judge reliability harness: Stress testing the reliability of LLM judges, in: Agents in the Wild: Safety, Security, and Beyond Workshop, International Conference on Learning Representations (ICLR), 2026, arXiv:2603.05399. Corrected: this paper does not establish the duplicate- item practice an earlier draft cited it for; it perturbs formatting, paraphrase, verbosity and labels.

[49] A. Ryan, S. S. Noor, M. Erfan, S. Mitra, S. Mittal, M. R. Rahman, Evaluating open-source LLMs for multi-label ATT&CK technique classification on CTI reports, PREPRINT, not peer reviewed. arXiv:2606.18166. The quoted correlation is from the full text, not the abstract: "the Spearman rank correlation confirms a statistically significant relationship between parameter size and F_1 scores in this CTI classification task (ρ=0.85, p=0.014)" (2026).

[50] C. Snell, J. Lee, K. Xu, A. Kumar, Scaling LLM test-time compute optimally can be more effective than scaling parameters for reasoning, in: International Conference on Learning Representations (ICLR), 2025, oral. "In a FLOPs-matched evaluation, we find that on problems where a smaller base model attains somewhat non-trivial success rates, test-time compute can be used to outperform a 14x larger model".

[51] M. Hassid, T. Remez, J. Gehring, R. Schwartz, Y. Adi, The larger the better? Improved LLM code-generation via budget reallocation, in: First Conference on Language Modeling (COLM), 2024, the ranking flips and flips back on an inference-time choice alone: repeated small-model sampling gains up to 15% with a unit-test oracle, and loses to a single large-model output without one.

[52] M. Jin, Q. Yu, D. Shu, H. Zhao, W. Hua, Y. Meng, Y. Zhang, M. Du, The impact of reasoning step length on large language models, in: Findings of the Association for Computational Linguistics: ACL, 2024, pp. 1830–1842, cited as the counterweight: lengthening reasoning steps "considerably enhances LLMs' reasoning abilities". Read with Sun et al., the effect is task- and budget-dependent rather than monotone in either direction. `doi:10.18653/v1/2024.findings-acl.108`.

[53] `max_tokens` not respected on the non-chat endpoint, PREPRINT, not peer reviewed. ggml-org/llama.cpp issue #8634. Search result; the issue has not been read in full. Cited with the vllm issue to demote our own mechanism to a known integration wart, which is the conservative direction (2024).

[54] Request for a server-side output cap, PREPRINT, not peer reviewed. vllm-project/vllm issue #11976 (2024).

Appendix A. Reproducibility

The harnesses, the derivation of every number in this paper, the per-sample records they read and the scripts that build the figures and assemble this document are released with the paper under `tests/evaluation/`, checkpointed and resumable, with the repository recording which harness produced which result. Everything procedural therefore lives there, and this appendix carries only what a reader needs in order to interpret the measurements rather than to re-run them.

Appendix A.1. How the numbers get onto the page

Every number this paper states about its own results is generated from the committed per-sample records into a macro and referenced, never typed, and a key the document asks for that the derivation cannot produce stops the build rather than leaving a hole in the page. The reason is drift rather than tidiness. Over this project's history the same measurement was typed into five places and went stale in all of them, and a figure caption disagreed with the paragraph beside it for a month.

Three kinds of number are deliberately literal and marked as such at the point of use, so that a reader can tell a deliberate exemption from an oversight. Settings, such as a port or a step budget, which no analysis produces and which cannot go stale; the distinction is not visible in the digits, since 31 GiB of host memory is a setting and 2.3 GB paged out is a measurement. Values quoted from cited work, registered with the citation each belongs to and permitted only on a line carrying that citation, so a quoted figure cannot drift away from its source. And observations from diagnostic sessions whose raw output was never in scope for the retention rule, each registered with the dated record that carries it and presented as an observation rather than as a measurement from the archive. A check enforces all three, and refuses a declared setting whose value is one the analysis already derives, because that would be a way of laundering a measurement into a constant.

Appendix A.2. The model, the engine and the host

Table A.17: The local model and inference engine, pinned by digest and commit.

model	`Qwen/Qwen3.6-35B-A3B`, quantised IQ3_K_R4 by Unsloth
GGUF sha256	`d0de70ef…c4ea`, computed locally and matching the HuggingFace etag
HF revision	`cfd350fd…1f0d`
retrieved	2026-05-11
imatrix calibration dataset	`unsloth_calibration_Qwen3.6-35B-A3B.txt`, 510 entries over 76 chunks, from `Qwen3.6-35B-A3B-GGUF/imatrix_unsloth.gguf`
architecture	hybrid recurrent (SSM keys + `full_attention_interval=4`), confirmed from the GGUF metadata

Naming the imatrix dataset matters. Most papers reporting a quantisation level cannot say which calibration produced it, and two IQ3 quants of the same model are not the same artefact.

The engine is `ik_llama.cpp` at commit `eb570eb96689c235933b813693ca28ab9d3d26de`, *"MTP: Avoid per step SSM copy (#1778)"*. The binary could not identify itself, because `llama-server --version` prints `version: 0 (unknown)` on a build tree that was never a git checkout. The commit was recovered from a depth-1 clone vendored elsewhere in the project and then *proved* to describe the build, with identical 837-file source lists and, once line endings are normalised, exactly one file differing. We report the reconstruction rather than presenting the identifier as though it had been recorded, because build provenance must be captured at build time.

```
llama-server -m Qwen3.6-35B-A3B-IQ3_K_R4.gguf \
  -c 131072 -t 16 -fa on -ctk q8_0 -ctv q8_0 -ngl 999 \
  -ot "blk\.([1-3][0-9])\.ffn_(up|gate|down)_exps=CPU" \
  --context-shift on --jinja --host 0.0.0.0 --port 8080
```

The context is served at 131,072, half the model's native 262,144, and the launch command documented in the repository at one point specified `--n-cpu-moe 36` while the service ran 30 blocks on CPU. The command above is what ran.

The host is a single RTX 5060 with 31 GiB of RAM and 16 threads, and four measured properties bound what can be reproduced on it. `llama-server` grows with cumulative requests and does not plateau, from 10.4 GB fresh to 14.8 GB after a single full analyst pass and 18.1 GB after 60 minutes of multi-arm load. The growth is anonymous and unreclaimable, so a long paired run must restart the server between arms, which changes no decoding parameter and is therefore measurement-neutral. Serving at 64k instead of 131k does not lower the peak, at 14.6 against 14.8 GB, because the baseline is CPU-resident expert weights and the growth follows the context a pass actually consumes. Generation varies from 162 to 20 tokens/s across requests, because on this hybrid recurrent architecture llama.cpp writes and erases a 63 MiB recurrent-state checkpoint every few hundred tokens at ~39k tokens of context, so long-context calls are not slow in proportion; they fall off a cliff. And the Ghidra container is capped at 6 GB, its JVM `-Xmx4g` bounding the heap only, with measured RSS reaching 5.15 GB against that nominal 4 GB cap.

The working set does not fit alongside an interactive session, and that is a reproducibility fact rather than an operational one. Model server ~16 GB, analysis worker ~8 GB and disassembly container up to 6 GB leave nothing on a 31 GiB host, and arms measured under memory pressure are not commensurable with arms that were not. Long paired studies here are therefore run against an otherwise-idle host, and the harnesses record `MemAvailable`, `SwapFree` and the model server's resident-versus-swapped split at both ends of every arm. That screen can only be applied forward, because for arms already collected without it the state is gone and the honest label is `unattributable`, which is what Section 8.7 reports it cost.

Appendix A.3. Data and the sandbox

The dynamic cohort is n=100, Windows PE only, stratified by year at seed 20260810 with its digest recorded. The withdrawn drift study's manifest survives as 210 dated samples over 7 cohorts and 27 families, metadata only and no binaries, so that cohort can be reconstructed even though its results cannot. Per-sample outputs are stored for every study in this paper, a policy adopted after their absence cost us a result. Ground truth resolves a MalwareBazaar family signature to an in-repo MITRE `uses` fixture through an explicit alias map plus a CamelCase-split fallback, and it is uncurated at technique level, which Threats to Validity treats as a construct-validity limit rather than a footnote.

The sandbox is CAPE 2.5 at a private address, reachable only from one network. It has one analysis machine and no Linux VM, so only Windows PE can be analysed dynamically whatever the code's stated scope, and an ELF submitted there joins the 10,348 tasks that are never scheduled. Reports are retained for days rather than indefinitely: sampled across the full task-id range, 18 of 18 older tasks return `"Reports directory does not exist"` while a report from four days earlier survived, so the local archive of fetched reports is the only copy and submitting the same samples is not a reproduction recipe on its own. The instance also rate-limits, and its throttle response is byte-identical to its auth refusal, `{"error": true, "message": ""}` in both cases, so a harness that reads that string as a capability verdict will mis-classify a throttle as a missing permission, as we did briefly; re-calling a tool that worked minutes earlier tells them apart. A new Windows submission is scheduled in ~1 second and completes in ~5.5 minutes, which makes an n=100 cohort roughly 9 hours of sandbox time.

Appendix A.4. The comparison endpoints, and one parameter that decides everything

A reader reproducing any arm needs the configuration axis before the model names, because it is worth more F1 than any of them.

`enable_thinking` is honoured on DashScope and ignored on OpenRouter. Not rejected, but accepted, recorded in the result file, and not acted on. The rerun requesting it returned a 56.2% reasoning share against 56.5% without it, while on DashScope the same request produces 0.0%. This is the line in this appendix that matters most to anyone comparing arms, because the flag is worth 0.34 to 0.45 F1 on the two models where it can be set, and an arm can therefore be labelled matched while running the opposite configuration. `eval_parameter_size_series.py` selects arms on the measured reasoning share for exactly this reason, and refuses to correlate when fewer than three configuration-matched arms span three parameter counts, which on these endpoints is always.

The local server's output cap must be sent twice. `ChatOpenAI(max_tokens=N)` reaches the wire as `max_completion_tokens`, which `ik_llama.cpp` does not read, so the cap must also travel in `extra_body` as `max_tokens` and `n_predict`. Measured on this host, 48 requested yields 2805 generated with the renamed field alone

Table A.18: The inference endpoints each arm ran against, with the configuration measured rather than the configuration requested.

arm	endpoint	model	reasoning	n
local baseline	`ik_llama.cpp`, this host	Qwen3.6-35B-A3B (IQ3_K_R4)	off	25
frontier	OpenRouter	`nvidia/nemotron-3-super-120b-a12b:free`	on, not controllable	25 ×2
same weights, hosted	DashScope International	`qwen3.6-35b-a3b`	off	25
same weights, hosted	DashScope International	`qwen3.6-35b-a3b`	on	25
larger, hosted	DashScope International	`qwen3.6-plus`	off / on	25 each

and 48 with both. That server also truncates silently, returning `finish_reason: "stop"` at the cap and never `"length"`, with no `stopped_limit` field, so telemetry that detects truncation by finish reason will report zero however often the cap binds. Compare the generated-token count against the cap that was requested instead.

The frontier arm ran on a free tier allowing 50 requests per day with a 20-per-minute cap that applies whether or not credit has been purchased. The first attempt exhausted the daily quota mid-flight, 9 calls landing and 16 returning HTTP 429, and the n=9 estimate it produced was not merely imprecise but pointed the wrong way (Section 5.3). The arm reported here is the completed n=25 run from a fresh quota. The quota governs what a cohort-scale frontier arm costs in wall-clock rather than in dollars, since one call per sample over a 97-sample cohort is two days at that rate and a full-pipeline arm, at roughly 20 model requests per analysis, is not reachable on the free tier at all.

Appendix A.5. Two checks worth running before the studies they check

Two harnesses exist only because a result could not be believed. `verify_b3_mechanism.py` recomputes each ablation arm's cascade set from its seeded fixture and compares it against what the arm recorded; it is what established that a published finding of ours had measured the reconciliation step rather than a model. `probe_outbound_parameters.py` asks whether the server acts on each parameter we send it, by behaviour rather than by reading a response field, because a server that ignores a parameter does not report having done so. Separately, the judge-contribution study is run twice and the pair is kept, once with the output cap not reaching the server and once with it binding, because the comparison between the two is what isolates what the model's unparsable output contributes and neither run alone shows it.

Figures are generated from the same retained records as the text, with intervals recomputed by the seeded bootstrap rather than read out of a summary, so a figure and a sentence cannot drift apart without the script failing to reproduce one of them. This caught a live error. An ROC computed by naive descending sort returned AUC 0.458 against the 0.550 in our text, because 186 of 210 claims are tied at confidence 1.0 and tie handling decides the entire estimate. The text was right and the first draft of the figure was wrong, which is the ordinary direction for this check to fire and the reason for wiring it this way.